

DAI HOC QUOC GIA THANH PHO HO CHI MINH
TRUONG DAI HOC KHOA HOC TU NHIEEN
KHOA TOAN — TIN HOC

BAO CAO THUC HANH

Lab06 (Final): PHP Secure MVC Mini CRM

*Ung dung: **EduCRM** — **Training Center CRM***

Giang vien huong dan: TS. Tran Anh Tuan
Mon hoc: Lap trinh Web
Sinh vien thuc hien: Le Pham Hong Hien
MSSV: 22110059

TP. Ho Chi Minh, Thang 7/2026

Contents

1	Cau 1: Xay dung ung dung	3
1.1	Gioi thieu ung dung EduCRM	3
1.2	Kiem tra moi truong (T01)	3
1.3	Cau truc du an (T02)	4
1.4	Front Controller va Router (T03)	5
1.5	Session / Login flow (T04, T11, T12)	6
1.6	Helpers va Layout/Partial (T05, T06)	8
1.7	Form cong khai an toan + chong spam (T07, T08, T09)	8
1.8	Thiet ke database (T13, T14)	10
1.9	Ket noi PDO chuan (T15)	13
1.10	Repository — prepared statements (T16)	13
1.11	MVC dung trach nhien: vi du Controller -> Service -> Repository (T17, T18, T19)	14
1.12	CRUD Module A va Module B (T20, T22)	15
1.13	Duplicate handling (T21, T23)	15
1.14	Search / Pagination / Sort an toan (T24, T25)	18
1.15	Health JSON, 404/405 va Safe error + logging (T26–T28)	19
1.16	EXPLAIN / index (T29)	21
1.17	GitHub / README (T30)	21
1.18	Bang route day du	22
2	Checklist task T01–T30 va Test Result TC01–TC25	23
2.1	Checklist task nho T01–T30	23
2.2	Bang Test Result TC01–TC25	24
3	Cau 2: Problem Solving	26
3.1	Front Controller & Router	26
3.2	Secure form	26
3.3	PRG Pattern	26
3.4	Anti-spam co ban	26
3.5	Session/login flow	26
3.6	Logout, timeout va cookie flags	27
3.7	Remember me	27
3.8	Database schema	27
3.9	Prepared statements	27
3.10	Unique constraint & duplicate handling	27
3.11	Search/pagination/sort safe	28
3.12	Index & EXPLAIN	28
3.13	MVC dung trach nhien	28
3.14	Layout/Partial & XSS	28
3.15	Dev/prod error message	28
3.16	404 vs 405	28
3.17	Delete bang POST	29
3.18	Huong phat trien that	29

4	Tinh nang mo rong nang cao va giao dien hien dai	30
4.1	F1 — Chuyen Lead thanh Phieu thu (transaction)	30
4.2	F2 — Soft delete + Thung rac (Restore)	30
4.3	F3 — Audit log (nhat ky hoat dong)	31
4.4	F4 — Export CSV an toan	32
4.5	F5 — Dashboard analytics	32
4.6	Giao dien hien dai (redesign)	32
4.7	Tinh nang F6–F11 (CRM nang cao)	32
4.8	Module C — Quan ly Khoa hoc (CRUD + anh + phan quyen)	33
4.9	Quick Wins: nang cap thong ke va trai nghiem nguoi dung	34
4.10	Bangkiem thu tinh nang mo rong (verify live)	40
4.11	Problem Solving (tinh nang moi)	41
5	Ket luan	42

1 Cau 1: Xay dung ung dung

1.1 Gioi thieu ung dung EduCRM

Em chon xay dung mot **Secure MVC Mini CRM** cho bai toan **Training Center CRM** — dat ten la **EduCRM**. EduCRM la he thong quan ly tu van va hoc phi cho mot trung tam dao tao, gom hai nghiep vu chinh:

- **Module A — Lead (/leads)**: quan ly lead tu van / hoc vien tiem nang (ho ten, email, so dien thoai, khoa hoc quan tam, nguon, trang thai cham soc).
- **Module B — Phieu hoc phi / Order (/orders)**: quan ly phieu thanh toan hoc phi gan voi tung lead, co `order_code` duy nhat va trang thai thanh toan.

Ngoai ra co **form dang ky tu van cong khai (/public-leads/create)** cho khach truy cap, **dang nhap nhan vien** bang session va **dashboard thong ke**. Du an khong giu lai bai mau generic: ten project, database (`training_center_crm`), bang, cot, route, controller, service, repository, view, du lieu mau va thong bao loi deu duoc dat lai theo bai toan trung tam dao tao.

1.2 Kiem tra moi truong (T01)

- **PHP**: 8.2.12 (XAMPP), chay qua `php -S 127.0.0.1:8106 -t public`.
- **MySQL**: MariaDB/MySQL trong XAMPP, user root, database `training_center_crm`.
- **Autoload**: PSR-4 App\ -> app/ (khong can Composer global).
- **Cong cu test**: curl (kiem tra route, status code, redirect, JSON).
- **Git/GitHub**: <https://github.com/lphhien112-gif/PHP->

```
# ===== T01: Kiem tra moi truong =====
C:\xampp\htdocs\PHP\PHP-Lab06\EduCRM> C:\xampp\php\php.exe -v
PHP 8.2.12 (cli) (built: Oct 24 2023 21:15:15) (ZTS Visual C++ 2019 x64)
Copyright (c) The PHP Group
Zend Engine v4.2.12, Copyright (c) Zend Technologies

C:\xampp\htdocs\PHP\PHP-Lab06\EduCRM> C:\xampp\mysql\bin\mysql.exe -u root -e "SELECT 1"
+----+
| 1 |
+----+
| 1 |
+----+

# ===== T02: Cau truc du an (Controller -> Service -> Repository -> View) =====
C:\xampp\htdocs\PHP\PHP-Lab06\EduCRM> tree /F
EduCRM\
├─ public\           # Web root
├─ index.php        # Front Controller (entry point duy nhat) + khai bao route
├─ assets\          # css, anh khoa hoc / tu van
├─ config\          # app.php (whitelist, rate limit), database.php
├─ app\
│   ├── Core\       Database.php, Router.php, helpers.php, Csv.php, *Exception.php
│   ├── Controllers\ Auth, Dashboard, PublicLead, Lead, Order, Course, Audit, Api, Health
│   ├── Services\    Auth, Lead, Order, Course, Dashboard, Audit, Api
│   ├── Repositories\ User, Lead, Order, Course, Stats, Audit, ApiToken, LoginAttempt, RememberToken
│   └─ Views\        layouts\, partials\, auth\, dashboard\, analytics\,
│                      leads\, orders\, courses\, audit\, public-leads\, errors\
├─ database\        # schema.sql, seed.sql
├─ storage\         # logs/app.log
└─ vendor\          # PSR-4 autoload: App\ -> app\

C:\xampp\htdocs\PHP\PHP-Lab06\EduCRM> C:\xampp\php\php.exe -S 127.0.0.1:8106 -t public
[Fri Jul 3 2026] PHP 8.2.12 Development Server (http://127.0.0.1:8106) started
```

Figure 1: T01/T02: kiem tra moi truong that — `php -v` (PHP 8.2.12), `mysql -e "SELECT 1"` (DB song), cay thu muc du an theo lop Controller/Service/Repository/View, va lenh chay server `php -S 127.0.0.1:8106 -t public`.

1.3 Cau truc du an (T02)

```

EduCRM/
|-- public/
|   |-- index.php           # Front Controller (entry point duy nhat)
|   '-- assets/app.css      # Stylesheet
|-- config/
|   |-- app.php             # debug, timeout, rate limit, whitelist khoa hoc/trang thai
|   '-- database.php        # thong tin ket noi MySQL
|-- app/
|   |-- Core/
|   |   |-- Database.php    # PDO singleton chuan
|   |   |-- Router.php      # map METHOD+PATH; 404/405
|   |   |-- helpers.php     # e, redirect, render, partial, flash, old, require_login, csrf
|   |   '-- DuplicateRecordException.php # loi trung UNIQUE -> field error
|   |-- Controllers/        # THIN: doc request -> Service -> render/redirect
|   |   |-- AuthController.php
|   |   |-- DashboardController.php
|   |   |-- PublicLeadController.php
|   |   |-- LeadController.php      # Module A
|   |   |-- OrderController.php     # Module B
|   |   '-- HealthController.php
|   |-- Services/             # business rule: validate, pagination, duplicate
|   |   |-- AuthService.php
|   |   |-- LeadService.php
|   |   '-- OrderService.php
|   |-- Repositories/        # TAT CA SQL (prepared statement, khong doc $_POST)
|   |   |-- UserRepository.php
|   |   |-- LeadRepository.php
|   |   '-- OrderRepository.php
|   '-- Views/               # chi hien thi, escape bang e()
|       |-- layouts/{main,auth,public,error}.php
|       |-- partials/{nav,flash}.php
|       |-- auth/login.php
|       |-- dashboard/index.php
|       |-- leads/{index,create,edit}.php
|       |-- orders/{index,create,edit}.php
|       |-- public-leads/create.php
|       '-- errors/{404,405,500}.php
|-- database/{schema.sql, seed.sql}
|-- storage/logs/app.log
|-- vendor/                  # PSR-4 autoload (App\ -> app/)
'-- README.md

```

1.4 Front Controller va Router (T03)

Moi request deu di qua `public/index.php`. File nay: (1) cho `php -S` phuc vu file tinh, (2) khai tao session voi cookie flags an toan, (3) load autoload + helpers, (4) khai bao toan bo route tap trung, (5) dispatch trong khoi `try/catch` de xu ly loi an toan.

Listing 1: `public/index.php` — khai bao route (rut gon)

```
$router = new Router();
$router->get('/login', [$auth, 'loginForm']);
$router->post('/login', [$auth, 'handleLogin']);
$router->post('/logout', [$auth, 'logout']);
$router->get('/dashboard', [$dashboard, 'index']);
$router->get('/public-leads/create', [$publicId, 'create']);
$router->post('/public-leads', [$publicId, 'store']);
// Module A - Leads
$router->get('/leads', [$leads, 'index']);
$router->post('/leads/store', [$leads, 'store']);
$router->post('/leads/delete', [$leads, 'delete']);
// Module B - Orders
$router->get('/orders', [$orders, 'index']);
$router->post('/orders/store', [$orders, 'store']);
// Health JSON
$router->get('/health', [$health, 'index']);

$router->setNotFoundHandler(fn() => render_error(404, '404'));
$router->setMethodNotAllowedHandler(fn($a) => render_error(405, '405',
    , ['allowed'=>$a]));
```

`Router::dispatch()` phan biet ro **404** (path khong ton tai) va **405** (path ton tai nhung sai method, kem header Allow):

Listing 2: `app/Core/Router.php` — `dispatch()`

```
public function dispatch(string $requestMethod, string $requestPath):
    void
{
    $requestMethod = strtoupper($requestMethod);
    $requestPath = $this->normalize($requestPath);

    // Buoc 1: khop chinh xac METHOD + PATH
    foreach ($this->routes as $route) {
        if ($route['method'] === $requestMethod && $route['path'] ===
            $requestPath) {
            call_user_func($route['handler']); return;
        }
    }
    // Buoc 2: path ton tai nhung khac method -> 405 + Allow
    $allowed = [];
    foreach ($this->routes as $route) {
        if ($route['path'] === $requestPath) { $allowed[] = $route['
            method']; }
    }
    if (!empty($allowed)) {
        header('Allow: ' . implode(', ', array_unique($allowed)));
        call_user_func($this->methodNotAllowedHandler, $allowed);
        return;
    }
}
```

```
// Bước 3: path không tồn tại -> 404
call_user_func($this->notFoundHandler);
}
```

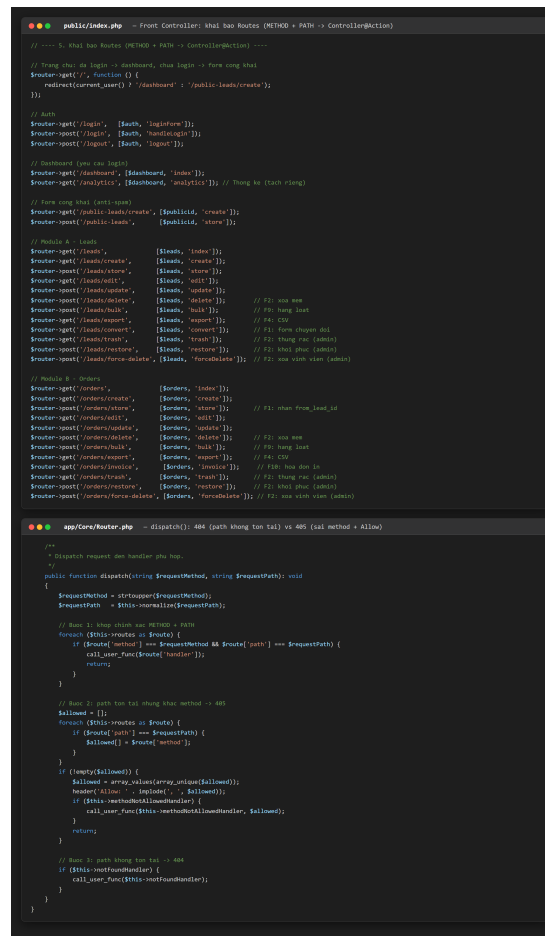


Figure 2: T03: code that `public/index.php` (khai bao toan bo route METHOD + PATH -> Controller@Action, gom Module A/B/C + F1-F12) va `app/Core/Router.php` `dispatch()` phan biet 404 (path không tồn tại) vs 405 (sai method + header Allow).

1.5 Session / Login flow (T04, T11, T12)

Trước `session_start()`, Front Controller gọi `session_set_cookie_params()` để đặt cookie flags an toàn:

Listing 3: public/index.php — cookie flags an toan

```

$isHttps = (!empty($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off')
|| (($_SERVER['SERVER_PORT'] ?? null) == 443);
session_set_cookie_params([
    'lifetime' => 0,
    'path'     => '/',
    'secure'   => $isHttps, // Secure khi HTTPS (production)
    'httponly' => true,     // JS không đọc được cookie -> giảm XSS
                        steal
    'samesite' => 'Lax',    // giảm CSRF cross-site
]);
session_start();

```

Flow đang nhập dung: validate input -> verify password -> session_regenerate_id(true)
-> set session -> flash -> redirect /dashboard. Logic password/session nam o
AuthService, controller chi dieu phoi:

Listing 4: app/Services/AuthService.php — attempt() va login()

```

public function attempt(string $username, string $password): array
{
    $username = trim($username);
    if ($username === '' || $password === '')
        return ['ok'=>false, 'error'=>'Vui long nhap day du ten dang
            nhap va mat khau.'];
    $user = $this->users->findByUsername($username);
    if (!$user || !password_verify($password, $user['password_hash']))
    {
        log_app('warning', 'Login failed for username=' . $username);
        return ['ok'=>false, 'error'=>'Ten dang nhap hoac mat khau
            khong dung.'];
    }
    return ['ok'=>true, 'user'=>[...]];
}

public function login(array $user): void
{
    session_regenerate_id(true); // chong session fixation
    $_SESSION['user']           = $user;
    $_SESSION['login_at']       = time();
    $_SESSION['last_activity']  = time();
}

```

Logout xoa sach session data, xoa cookie session va destroy:

Listing 5: app/Services/AuthService.php — logout()

```

public function logout(): void
{
    $_SESSION = [];
    if (ini_get('session.use_cookies')) {
        $p = session_get_cookie_params();
        setcookie(session_name(), '', time() - 42000,
            $p['path'], $p['domain'], $p['secure'], $p['httponly']);
    }
    session_destroy();
}

```

Idle timeout: helper `require_login()` kiểm tra `last_activity`; nếu không hoạt động qua 1800 giây (30 phút) sẽ đăng xuất và redirect `/login` kèm flash.

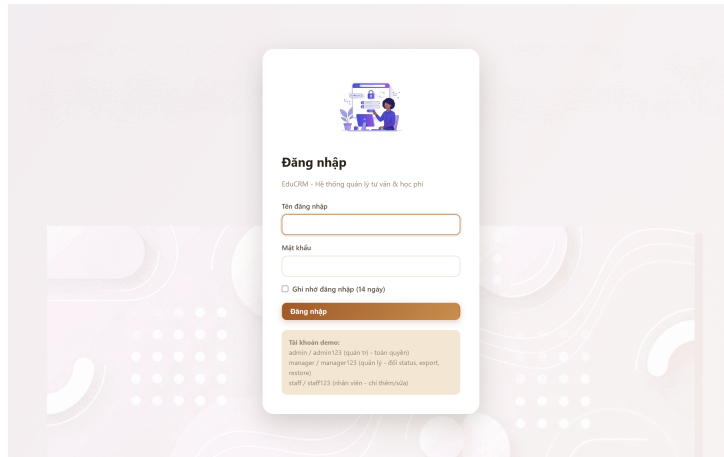


Figure 3: Form đăng nhập (GET `/login`): có CSRF token an, tài khoản demo, login đúng sẽ redirect sang dashboard (T10, T11).

1.6 Helpers va Layout/Partial (T05, T06)

Các helper bắt buộc được định nghĩa trong `app/Core/helpers.php`: `e()`, `redirect()`, `render()`, `partial()`, `flash()/get_flash()`, `old()`, `require_login()`; bổ sung `csrf_token()`, `csrf_field()`, `verify_csrf()`, `log_app()`.

Listing 6: `helpers.php` — `render()` lập view con vào layout chung

```
function render(string $view, array $data = [], ?string $layout = '
    layouts/main'): string
{
    extract($data, EXTR_SKIP);
    ob_start(); require view_path($view); $content = ob_get_clean();
    if ($layout === null) return $content;
    ob_start(); require view_path($layout); return ob_get_clean();
}
function e(?string $value): string {
    return htmlspecialchars((string)$value, ENT_QUOTES |
        ENT_SUBSTITUTE, 'UTF-8');
}
```

Layout `layouts/main.php` dùng chung header (nav) + flash; view con không lặp lại HTML header/footer. Partial `partials/nav.php` và `partials/flash.php` được nhúng qua `partial()`.

1.7 Form công khai an toàn + chống spam (T07, T08, T09)

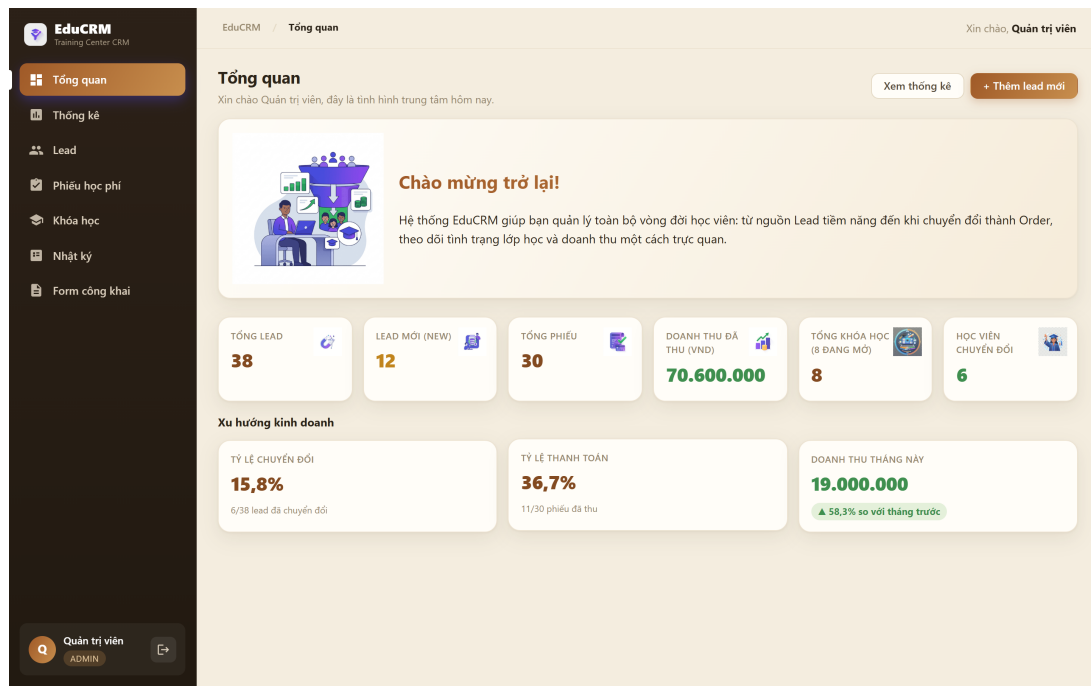


Figure 4: Dashboard EduCRM sau khi đăng nhập: layout chung + nav + thông kê (tổng lead/order, doanh thu, lead theo trạng thái) (T06).

`PublicLeadController::store()` thực hiện tuân tu: (1) kiểm tra honeypot, (2) rate limit theo session, (3) validate server-side qua `LeadService`, (4) PRG sau khi thành công.

Listing 7: `app/Controllers/PublicLeadController.php` — `store()` (rút gọn)

```
// 1. Honeypot: field an "website" phải rỗng. Bot thường điền hết field.
if (trim((string)($_POST['website'] ?? '')) !== '') {
    log_app('warning', 'Honeypot triggered ...');
    flash('success', 'Cam ơn bạn, chúng tôi sẽ liên hệ sớm!'); // giả
    // vo thành công
    redirect('/public-leads/create');
}
// 2. Rate limit theo session (tối đa 5 lần / 300 giây)
if ($this->isRateLimited()) {
    flash('error', 'Bạn gửi quá nhanh. Vui lòng thử lại sau vài phút.
    ');
    set_old($_POST, []); redirect('/public-leads/create');
}
// 3. Validate server-side + old input khi lỗi
$result = $this->leads->create($input, 'new');
if (!$result['ok']) {
    set_old($input, $result['errors']);
    redirect('/public-leads/create');
}
// 4. PRG: redirect sau POST thành công -> F5 không tạo trùng
$this->recordSubmission();
flash('success', 'Đăng ký thành công! ...');
redirect('/public-leads/create');
```

Validate server-side (trong `LeadService::validate()`) kiểm tra: required, định dạng

email (filter_var FILTER_VALIDATE_EMAIL), so dien thoai (regex / $\odot\backslash\{9,10\}\$/$), do dai, va course phai nam trong whitelist khoa hoc.

EduCRM
Trung tâm đào tạo - Đăng ký tư vấn khóa học miễn phí

Đăng ký nhận tư vấn
Diễn thông tin, đội ngũ tư vấn của chúng tôi sẽ liên hệ trong 24h.

Họ tên * Email *

Số điện thoại * Khóa học quan tâm *

Ghi chú thêm

Gửi đăng ký

Bạn là nhân viên? Đăng nhập hệ thống

Figure 5: Form công khai GET /public-leads/create: có honeypot an, layout public riêng (T07).

1.8 Thiết kế database (T13, T14)

Database training_center_crm có 3 bảng: users, leads, orders. Tất cả dùng engine InnoDB, charset utf8mb4_unicode_ci, có created_at / updated_at.

Listing 8: database/schema.sql — bảng leads (Module A)

```
CREATE TABLE leads (
  id          INT UNSIGNED NOT NULL AUTO_INCREMENT,
  full_name   VARCHAR(120) NOT NULL,
  email       VARCHAR(150) NOT NULL,
  phone       VARCHAR(20)  NOT NULL,
  course      VARCHAR(80)  NOT NULL,
  source      VARCHAR(40)  NOT NULL DEFAULT 'website',
  status      ENUM('new', 'contacted', 'qualified', 'converted', 'lost')
              NOT NULL DEFAULT 'new',
  note        VARCHAR(500) NULL,
  created_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
              CURRENT_TIMESTAMP,
  PRIMARY KEY (id),
  UNIQUE KEY uq_leads_email (email),           -- chống trùng email
  KEY idx_leads_status (status),               -- hỗ trợ filter theo
  KEY idx_leads_course (course),
  KEY idx_leads_created_at (created_at)       -- hỗ trợ sort mặc định
)
```

Figure 6: Validate server-side: submit thiếu field bắt buộc -> lỗi theo từng field và giữ lại old input (Bob) (T08).

```
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;
```

Listing 9: database/schema.sql — bang orders (Module B)

```
CREATE TABLE orders (
  id          INT UNSIGNED NOT NULL AUTO_INCREMENT,
  order_code  VARCHAR(30)  NOT NULL,
  lead_id     INT UNSIGNED NOT NULL,
  course      VARCHAR(80)  NOT NULL,
  amount      DECIMAL(12,2) NOT NULL DEFAULT 0,
  status      ENUM('pending','paid','refunded','cancelled') NOT NULL
              DEFAULT 'pending',
  paid_at     DATE NULL,
  note        VARCHAR(500) NULL,
  created_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
              CURRENT_TIMESTAMP,
  PRIMARY KEY (id),
  UNIQUE KEY uq_orders_code (order_code), -- chong trung ma phieu
  KEY idx_orders_status (status),
  KEY idx_orders_lead_id (lead_id),
  KEY idx_orders_created_at (created_at),
  CONSTRAINT fk_orders_lead FOREIGN KEY (lead_id) REFERENCES leads
              (id)
              ON DELETE CASCADE ON UPDATE CASCADE
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;
```

Khoa và rang buoc:

- **Primary key:** users.id, leads.id, orders.id (auto increment).
- **Unique:** users.username, leads.email, orders.order_code.
- **Foreign key:** orders.lead_id -> leads.id (ON DELETE CASCADE).
- **Index:** status, course, lead_id, created_at.
- **Timestamp:** created_at, updated_at (auto cap nhat).

Seed (T14): **3 tài khoản demo** (admin/admin123, staff/staff123, manager/manager123 — mật khẩu password_hash bcrypt) cung dữ liệu nghiệp vụ để test pagination và biểu đồ. Sau khi phát triển Module C + seed dữ liệu gần đây cho chart, kiểm tra SELECT COUNT(*) cho kết quả thực tế: **users=3, leads=38, orders=30, courses=8** (mỗi module nghiệp vụ ≥ 20 dòng — xem ảnh T13/T14 ở dưới).

```
# ===== T13/T14: Schema + Seed (kiểm tra bằng SELECT COUNT) =====
MariaDB [training_center_crm]> SHOW TABLES;
+-----+
| Tables_in_training_center_crm |
+-----+
| activity_logs |
| api_tokens |
| courses |
| leads |
| login_attempts |
| orders |
| remember_tokens |
| users |
+-----+
8 rows in set (0.001 sec)

MariaDB [training_center_crm]> DESCRIBE leads;
+-----+-----+-----+-----+-----+-----+
| Field | Type | Null | Key | Default | Extra |
+-----+-----+-----+-----+-----+-----+
| id | int(10) unsigned | NO | PRI | NULL | auto_increment |
| full_name | varchar(120) | NO | | NULL | |
| email | varchar(150) | NO | | NULL | |
| phone | varchar(20) | NO | | NULL | |
| course | varchar(80) | NO | MUL | NULL | |
| source | varchar(40) | NO | | website | |
| status | enum('new','contacted','qualified','converted','lost') | NO | MUL | new | |
| note | varchar(500) | YES | | NULL | |
| deleted_at | timestamp | YES | MUL | NULL | |
| email_active | varchar(150) | YES | UNI | NULL | STORED GENERATED |
| created_at | timestamp | NO | MUL | current_timestamp() | |
| updated_at | timestamp | NO | | current_timestamp() | on update current_timestamp() |
+-----+-----+-----+-----+-----+-----+
12 rows in set (0.002 sec)
-- email_active = STORED GENERATED (IF deleted_at IS NULL THEN email) + UNIQUE -> chống trùng mã và soft-delete được [M1].

MariaDB [training_center_crm]> SELECT 'users' t, COUNT(*) c FROM users UNION ALL SELECT 'leads',COUNT(*) FROM leads
-> UNION ALL SELECT 'orders',COUNT(*) FROM orders UNION ALL SELECT 'courses',COUNT(*) FROM courses;
+-----+-----+
| t | c |
+-----+-----+
| users | 3 |
| leads | 38 |
| orders | 30 |
| courses | 8 |
+-----+-----+
4 rows in set (0.001 sec)
-- Seed day du: 3 tài khoản demo (admin/staff/manager) + 38 leads + 30 orders + 8 khóa học (>= 20 dòng/module).
```

Figure 7: T13/T14: schema that trong MariaDB — SHOW TABLES (8 bảng), DESCRIBE leads (PK / MUL index / cột sinh email_active UNIQUE STORED GENERATED theo M1), và SELECT COUNT(*) kiểm tra seed: users=3, leads=38, orders=30, courses=8 (đều ≥ 20 dòng/module nghiệp vụ).

1.9 Ket noi PDO chuan (T15)

Listing 10: app/Core/Database.php — PDO chuan

```
$options = [
    PDO::ATTR_ERRMODE          => PDO::ERRMODE_EXCEPTION,
    PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
    PDO::ATTR_EMULATE_PREPARES => false, // prepared statement
                                   native MySQL
];
$dsn = "mysql:host=127.0.0.1;port=3306;dbname=training_center_crm;
        charset=utf8mb4";
self::$instance = new PDO($dsn, 'root', '', $options);
```

Lưu ý kỹ thuật (gap that khi build): với EMULATE_PREPARES=false, MySQL native prepared statement **không cho dùng lại** một named placeholder nhiều lần. Ban đầu em viết LIKE :q OR ... LIKE :q (3 lần) gây lỗi HY093 Invalid parameter number. Em đã sửa: mỗi cột một placeholder riêng (:q_name, :q_email, :q_phone).

1.10 Repository — prepared statements (T16)

Toàn bộ SQL nằm ở Repository, dùng prepare/execute/bindValue, không nối trực tiếp input vào SQL.

Listing 11: app/Repositories/LeadRepository.php — create() (INSERT prepared)

```
public function create(array $data): int
{
    $sql = 'INSERT INTO leads (full_name, email, phone, course,
        source, status, note)
        VALUES (:full_name, :email, :phone, :course, :source, :
            status, :note)';

    try {
        $stmt = $this->db()->prepare($sql);
        $stmt->execute([
            ':full_name' => $data['full_name'], ':email' => $data['
                email'],
            ':phone' => $data['phone'], ':course' => $data['course'],
            ':source' => $data['source'], ':status' => $data['status']
        ],
            ':note' => $data['note'],
        ]);
        return (int) $this->db()->lastInsertId();
    } catch (PDOException $e) {
        if ($this->isDuplicate($e))
            throw new DuplicateRecordException('email', 'Email này đã
                tồn tại trong hệ thống.');
```

Listing 12: app/Repositories/LeadRepository.php — paginate() (SELECT prepared + whitelist sort)

```
public function paginate(string $q, string $status, string $sort,
    string $dir,
```

```

        int $limit, int $offset): array
    {
        // Lop bao ve thu 2: whitelist cot + direction TRUOC khi ghep
        ORDER BY
        $sort = in_array($sort, self::SORTABLE, true) ? $sort : '
            created_at';
        $dir = strtoupper($dir) === 'ASC' ? 'ASC' : 'DESC';
        [$where, $params] = $this->buildWhere($q, $status);

        $sql = "SELECT id, full_name, email, phone, course, source,
            status, note, created_at
            FROM leads $where ORDER BY $sort $dir LIMIT :limit OFFSET
                :offset";
        $stmt = $this->db()->prepare($sql);
        foreach ($params as $k => $v) $stmt->bindValue($k, $v, PDO::
            PARAM_STR);
        $stmt->bindValue(':limit', $limit, PDO::PARAM_INT);
        $stmt->bindValue(':offset', $offset, PDO::PARAM_INT);
        $stmt->execute();
        return $stmt->fetchAll();
    }

```

1.11 MVC dung trach nhien: vi du Controller -> Service -> Repository (T17, T18, T19)

De chung minh Controller khong viet SQL va View khong query DB, xet luong tao lead:

(1) Controller (mong) — chi doc request, goi service, render/redirect:

Listing 13: app/Controllers/LeadController.php — store()

```

public function store(): void
{
    require_login();
    if (!verify_csrf()) { flash('error', 'Phien khong hop le (CSRF).');
        redirect('/leads/create'); }
    $result = $this->leads->create($_POST, $_POST['status'] ?? 'new')
        ;
    if (!$result['ok']) {
        set_old($_POST, $result['errors']);
        flash('error', 'Khong the tao lead. Vui long kiem tra lai.');
```

redirect('/leads/create');

```

    }
    flash('success', 'Da them lead moi thanh cong.');
```

redirect('/leads');

```

}

```

(2) Service — giu business rule: validate, sanitize, bat duplicate:

Listing 14: app/Services/LeadService.php — create()

```

public function create(array $input, string $defaultStatus = 'new'):
    array
{
    $errors = $this->validate($input); // validate server-
        side

```

```

if ($errors) return ['ok'=>false, 'errors'=>$errors];
$data = $this->sanitize($input, $defaultStatus);
try {
    $id = $this->repo->create($data);
    return ['ok'=>true, 'id'=>$id];
} catch (DuplicateRecordException $e) {
    return ['ok'=>false, 'errors'=>[$e->field() => $e->getMessage()]];
}
}

```

(3) **Repository** — chi SQL (xem create() o muc tren). (4) **View** — chi hien thi, escape moi output bang e():

Listing 15: app/Views/leads/index.php — View chi hien thi + escape

```

<td><?= e($r['full_name']) ?></td>
<td><?= e($r['email']) ?></td>
<td><span class="badge <?= e($r['status']) ?>"><?= e($r['status'])
?></span></td>

```

Em da kiem chung bang **grep**: thu muc **Controllers/** va **Views/** **khong co** `->prepare / ->query / INSERT / DELETE`; thu muc **Repositories/** va **Services/** **khong** `doc $_POST/$_GET` (chi xuất hiện trong comment).

1.12 CRUD Module A va Module B (T20, T22)

Ca hai module co day du List / Create / Edit / Update / Delete; cac thao tac thay doi du lieu (**store**, **update**, **delete**) deu dung **POST**. Module B (orders) co them **transaction** khi tao phieu va **JOIN** sang leads de hien ten hoc vien.

1.13 Duplicate handling (T21, T23)

Khi trung **UNIQUE** (email lead hoac order_code), Repository bat **PDOException** co **SQLSTATE=23000 / errno 1062** va nem **DuplicateRecordException** gan ten field; Service chuyen thanh loi theo field, hien thi than thien **ma khong lo SQLSTATE**.

Listing 16: app/Core/DuplicateRecordException.php

```

class DuplicateRecordException extends RuntimeException {
    private string $field;
    public function __construct(string $field, string $message = '')
    {
        $this->field = $field;
        parent::__construct($message ?: "Gia tri truong $field da ton
            tai.");
    }
    public function field(): string { return $this->field; }
}

```

Ket qua test: tao lead trung email -> *"Email nay da ton tai trong he thong."*; tao order trung ma -> *"Ma phieu nay da ton tai."* (khong co **SQLSTATE**).

```

app > controllers > LeadController.php
1
2
3
4 class LeadController
5 {
6     public __construct(LeadServices) {
7         $this->injector->LeadService;
8     }
9
10
11 public function store(Request $request) {
12     try {
13         $data = $this->LeadService->processAndCreate(
14             ($request->all()),
15             ($request->all()));
16         return response()->json(['status' => 'success',
17             'data' => $data], 201);
18     } catch (ValidationException $e) {
19         return response()->json(['status' => 'error',
20             'errors' => $e->getErrors()], 422);
21     }
22 }
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
101
102
103
104
105
106
107
108
109
110
111
112
113
114
115
116
117
118
119
120
121
122
123
124
125
126
127
128
129
130
131
132
133
134
135
136
137
138
139
140
141
142
143
144
145
146
147
148
149
150
151
152
153
154
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
188
189
190
191
192
193
194
195
196
197
198
199
200
201
202
203
204
205
206
207
208
209
210
211
212
213
214
215
216
217
218
219
220
221
222
223
224
225
226
227
228
229
230
231
232
233
234
235
236
237
238
239
240
241
242
243
244
245
246
247
248
249
250
251
252
253
254
255
256
257
258
259
260
261
262
263
264
265
266
267
268
269
270
271
272
273
274
275
276
277
278
279
280
281
282
283
284
285
286
287
288
289
290
291
292
293
294
295
296
297
298
299
300
301
302
303
304
305
306
307
308
309
310
311
312
313
314
315
316
317
318
319
320
321
322
323
324
325
326
327
328
329
330
331
332
333
334
335
336
337
338
339
340
341
342
343
344
345
346
347
348
349
350
351
352
353
354
355
356
357
358
359
360
361
362
363
364
365
366
367
368
369
370
371
372
373
374
375
376
377
378
379
380
381
382
383
384
385
386
387
388
389
390
391
392
393
394
395
396
397
398
399
400
401
402
403
404
405
406
407
408
409
410
411
412
413
414
415
416
417
418
419
420
421
422
423
424
425
426
427
428
429
430
431
432
433
434
435
436
437
438
439
440
441
442
443
444
445
446
447
448
449
450
451
452
453
454
455
456
457
458
459
460
461
462
463
464
465
466
467
468
469
470
471
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517
518
519
520
521
522
523
524
525
526
527
528
529
530
531
532
533
534
535
536
537
538
539
540
541
542
543
544
545
546
547
548
549
550
551
552
553
554
555
556
557
558
559
560
561
562
563
564
565
566
567
568
569
570
571
572
573
574
575
576
577
578
579
580
581
582
583
584
585
586
587
588
589
590
591
592
593
594
595
596
597
598
599
600
601
602
603
604
605
606
607
608
609
610
611
612
613
614
615
616
617
618
619
620
621
622
623
624
625
626
627
628
629
630
631
632
633
634
635
636
637
638
639
640
641
642
643
644
645
646
647
648
649
650
651
652
653
654
655
656
657
658
659
660
661
662
663
664
665
666
667
668
669
670
671
672
673
674
675
676
677
678
679
680
681
682
683
684
685
686
687
688
689
690
691
692
693
694
695
696
697
698
699
700
701
702
703
704
705
706
707
708
709
710
711
712
713
714
715
716
717
718
719
720
721
722
723
724
725
726
727
728
729
730
731
732
733
734
735
736
737
738
739
740
741
742
743
744
745
746
747
748
749
750
751
752
753
754
755
756
757
758
759
760
761
762
763
764
765
766
767
768
769
770
771
772
773
774
775
776
777
778
779
780
781
782
783
784
785
786
787
788
789
790
791
792
793
794
795
796
797
798
799
800
801
802
803
804
805
806
807
808
809
810
811
812
813
814
815
816
817
818
819
820
821
822
823
824
825
826
827
828
829
830
831
832
833
834
835
836
837
838
839
840
841
842
843
844
845
846
847
848
849
850
851
852
853
854
855
856
857
858
859
860
861
862
863
864
865
866
867
868
869
870
871
872
873
874
875
876
877
878
879
880
881
882
883
884
885
886
887
888
889
890
891
892
893
894
895
896
897
898
899
900
901
902
903
904
905
906
907
908
909
910
911
912
913
914
915
916
917
918
919
920
921
922
923
924
925
926
927
928
929
930
931
932
933
934
935
936
937
938
939
940
941
942
943
944
945
946
947
948
949
950
951
952
953
954
955
956
957
958
959
960
961
962
963
964
965
966
967
968
969
970
971
972
973
974
975
976
977
978
979
980
981
982
983
984
985
986
987
988
989
990
991
992
993
994
995
996
997
998
999
1000
1001
1002
1003
1004
1005
1006
1007
1008
1009
1010
1011
1012
1013
1014
1015
1016
1017
1018
1019
1020
1021
1022
1023
1024
1025
1026
1027
1028
1029
1030
1031
1032
1033
1034
1035
1036
1037
1038
1039
1040
1041
1042
1043
1044
1045
1046
1047
1048
1049
1050
1051
1052
1053
1054
1055
1056
1057
1058
1059
1060
1061
1062
1063
1064
1065
1066
1067
1068
1069
1070
1071
1072
1073
1074
1075
1076
1077
1078
1079
1080
1081
1082
1083
1084
1085
1086
1087
1088
1089
1090
1091
1092
1093
1094
1095
1096
1097
1098
1099
1100
1101
1102
1103
1104
1105
1106
1107
1108
1109
1110
1111
1112
1113
1114
1115
1116
1117
1118
1119
1120
1121
1122
1123
1124
1125
1126
1127
1128
1129
1130
1131
1132
1133
1134
1135
1136
1137
1138
1139
1140
1141
1142
1143
1144
1145
1146
1147
1148
1149
1150
1151
1152
1153
1154
1155
1156
1157
1158
1159
1160
1161
1162
1163
1164
1165
1166
1167
1168
1169
1170
1171
1172
1173
1174
1175
1176
1177
1178
1179
1180
1181
1182
1183
1184
1185
1186
1187
1188
1189
1190
1191
1192
1193
1194
1195
1196
1197
1198
1199
1200
1201
1202
1203
1204
1205
1206
1207
1208
1209
1210
1211
1212
1213
1214
1215
1216
1217
1218
1219
1220
1221
1222
1223
1224
1225
1226
1227
1228
1229
1230
1231
1232
1233
1234
1235
1236
1237
1238
1239
1240
1241
1242
1243
1244
1245
1246
1247
1248
1249
1250
1251
1252
1253
1254
1255
1256
1257
1258
1259
1260
1261
1262
1263
1264
1265
1266
1267
1268
1269
1270
1271
1272
1273
1274
1275
1276
1277
1278
1279
1280
1281
1282
1283
1284
1285
1286
1287
1288
1289
1290
1291
1292
1293
1294
1295
1296
1297
1298
1299
1300
1301
1302
1303
1304
1305
1306
1307
1308
1309
1310
1311
1312
1313
1314
1315
1316
1317
1318
1319
1320
1321
1322
1323
1324
1325
1326
1327
1328
1329
1330
1331
1332
1333
1334
1335
1336
1337
1338
1339
1340
1341
1342
1343
1344
1345
1346
1347
1348
1349
1350
1351
1352
1353
1354
1355
1356
1357
1358
1359
1360
1361
1362
1363
1364
1365
1366
1367
1368
1369
1370
1371
1372
1373
1374
1375
1376
1377
1378
1379
1380
1381
1382
1383
1384
1385
1386
1387
1388
1389
1390
1391
1392
1393
1394
1395
1396
1397
1398
1399
1400
1401
1402
1403
1404
1405
1406
1407
1408
1409
1410
1411
1412
1413
1414
1415
1416
1417
1418
1419
1420
1421
1422
1423
1424
1425
1426
1427
1428
1429
1430
1431
1432
1433
1434
1435
1436
1437
1438
1439
1440
1441
1442
1443
1444
1445
1446
1447
1448
1449
1450
1451
1452
1453
1454
1455
1456
1457
1458
1459
1460
1461
1462
1463
1464
1465
1466
1467
1468
1469
1470
1471
1472
1473
1474
1475
1476
1477
1478
1479
1480
1481
1482
1483
1484
1485
1486
1487
1488
1489
1490
1491
1492
1493
1494
1495
1496
1497
1498
1499
1500
1501
1502
1503
1504
1505
1506
1507
1508
1509
1510
1511
1512
1513
1514
1515
1516
1517
1518
1519
1520
1521
1522
1523
1524
1525
1526
1527
1528
1529
1530
1531
1532
1533
1534
1535
1536
1537
1538
1539
1540
1541
1542
1543
1544
1545
1546
1547
1548
1549
1550
1551
1552
1553
1554
1555
1556
1557
1558
1559
1560
1561
1562
1563
1564
1565
1566
1567
1568
1569
1570
1571
1572
1573
1574
1575
1576
1577
1578
1579
1580
1581
1582
1583
1584
1585
1586
1587
1588
1589
1590
1591
1592
1593
1594
1595
1596
1597
1598
1599
1600
1601
1602
1603
1604
1605
1606
1607
1608
1609
1610
1611
1612
1613
1614
1615
1616
1617
1618
1619
1620
1621
1622
1623
1624
1625
1626
1627
1628
1629
1630
1631
1632
1633
1634
1635
1636
1637
1638
1639
1640
1641
1642
1643
1644
1645
1646
1647
1648
1649
1650
1651
1652
1653
1654
1655
1656
1657
1658
1659
1660
1661
1662
1663
1664
1665
1666
1667
1668
1669
1670
1671
1672
1673
1674
1675
1676
1677
1678
1679
1680
1681
1682
1683
1684
1685
1686
1687
1688
1689
1690
1691
1692
1693
1694
1695
1696
1697
1698
1699
1700
1701
1702
1703
1704
1705
1706
1707
1708
1709
1710
1711
1712
1713
1714
1715
1716
1717
1718
1719
1720
1721
1722
1723
1724
1725
1726
1727
1728
1729
1730
1731
1732
1733
1734
1735
1736
1737
1738
1739
1740
1741
1742
1743
1744
1745
1746
1747
1748
1749
1750
1751
1752
1753
1754
1755
1756
1757
1758
1759
1760
1761
1762
1763
1764
1765
1766
1767
1768
1769
1770
1771
1772
1773
1774
1775
1776
1777
1778
1779
1780
1781
1782
1783
1784
1785
1786
1787
1788
1789
1790
1791
1792
1793
1794
1795
1796
1797
1798
1799
1800
1801
1802
1803
1804
1805
1806
1807
1808
1809
1810
1811
1812
1813
1814
1815
1816
1817
1818
1819
1820
1821
1822
1823
1824
1825
1826
1827
1828
1829
1830
1831
1832
1833
1834
1835
1836
1837
1838
1839
1840
1841
1842
1843
1844
1845
1846
1847
1848
1849
1850
1851
1852
1853
1854
1855
1856
1857
1858
1859
1860
1861
1862
1863
1864
1865
1866
1867
1868
1869
1870
1871
1872
1873
1874
1875
1876
1877
1878
1879
1880
1881
1882
1883
1884
1885
1886
1887
1888
1889
1890
1891
1892
1893
1894
1895
1896
1897
1898
1899
1900
1901
1902
1903
1904
1905
1906
1907
1908
1909
1910
1911
1912
1913
1914
1915
1916
1917
1918
1919
1920
1921
1922
1923
1924
1925
1926
1927
1928
1929
1930
1931
1932
1933
1934
1935
1936
1937
1938
1939
1940
1941
1942
1943
1944
1945
1946
1947
1948
1949
1950
1951
1952
1953
1954
1955
1956
1957
1958
1959
1960
1961
1962
1963
1964
1965
1966
1967
1968
1969
1970
1971
1972
1973
1974
1975
1976
1977
1978
1979
1980
1981
1982
1983
1984
1985
1986
1987
1988
1989
1990
1991
1992
1993
1994
1995
1996
1997
1998
1999
2000
2001
2002
2003
2004
2005
2006
2007
2008
2009
2010
2011
2012
2013
2014
2015
2016
2017
2018
2019
2020
2021
2022
2023
2024
2025
2026
2027
2028
2029
2030
2031
2032
2033
2034
2035
2036
2037
2038
2039
2040
2041
2042
2043
2044
2045
2046
2047
2048
2049
2050
2051
2052
2053
2054
2055
2056
2057
2058
2059
2060
2061
2062
2063
2064
2065
2066
2067
2068
2069
2070
2071
2072
2073
2074
2075
2076
2077
2078
2079
2080
2081
2082
2083
2084
2085
2086
2087
2088
2089
2090
2091
2092
2093
2094
2095
2096
2097
2098
2099
2100
2101
2102
2103
2104
2105
2106
2107
2108
2109
2110
2111
2112
2113
2114
2115
2116
2117
2118
2119
2120
2121
2122
2123
2124
2125
2126
2127
2128
2129
2130
2131
2132
2133
2134
2135
2136
2137
2138
2139
2140
2141
2142
2143
2144
2145
2146
2147
2148
2149
2150
2151
2152
2153
2154
2155
2156
2157
2158
2159
2160
2161
2162
2163
2164
2165
2166
2167
2168
2169
2170
2171
2172
2173
2174
2175
2176
2177
2178
2179
2180
2181
2182
2183
2184
2185
2186
2187
2188
2189
2190
2191
2192
2193
2194
2195
2196
2197
2198
2199
2200
2201
2202
2203
2204
2205
2206
2207
2208
2209
2210
2211
2212
2213
2214
2215
2216
2217
2218
2219
2220
2221
2222
2223
2224
2225
2226
2227
2228
2229
2230
2231
2232
2233
2234
2235
2236
2237
2238
2239
2240
2241
2242
2243
2244
2245
2246
2247
2248
2249
2250
2251
2252
2253
2254
2255
2256
2257
2258
2259
2260
2261
2262
2263
2264
2265
2266
2267
2268
2269
2270
2271
2272
2273
2274
2275
2276
2277
2278
2279
2280
2281
2282
2283
2284
2285
2286
2287
2288
2289
2290
2291
2292
2293
2294
2295
2296
2297
2298
2299
2300
2301
2302
2303
2304
2305
2306
2307
2308
2309
2310
2311
2312
2313
2314
2315
2316
2317
2318
2319
2320
2321
2322
2323
2324
2325
2326
2327
2328
2329
2330
2331
2332
2333
2334
2335
2336
2337
2338
2339
2340
2341
2342
2343
2344
2345
2346
2347
2348
2349
2350
2351
2352
2353
2354
2355
2356
2357
2358
2359
2360
2361
2362
2363
2364
2365
2366
2367
2368
2369
2370
2371
2372
2373
2374
2375
2376
2377
2378
2379
2380
2381
2382
2383
2384
2385
2386
2387
2388
2389
2390
2391
2392
2393
2394
2395
2396
2397
2398
2399
2400
2401
2402
2403
2404
2405
2406
2407
2408
2409
2410
2411
2412
2413
2414
2415
2416
2417
2418
2419
2420
2421
2422
2423
2424
2425
2426
2427
2428
2429
2430
2431
2432
2433
2434
2435
2436
2437
2438
2439
2440
2441
2442
2443
2444
2445
2446
2447
2448
2449
2450
2451
2452
2453
2454
2455
2456
2457
2458
2459
2460
2461
2462
2463
2464
2465
2466
2467
2468
2469
2470
2471
2472
2473
2474
2475
2476
2477
2478
2479
2480
2481
2482
2483
2484
2485
2486
2487
2488
2489
2490
2491
2492
2493
2494
2495
2496
2497
2498
2499
2500
2501
2502
2503
2504
2505
2506
2507
2508
2509
2510
2511
2512
2513
2514
2515
2516
2517
2518
2519
2520
2521
2522
2523
2524
2525
2526
2527
2528
2529
2530
2531
2532
2533
2534
2535
2536
2537
2538
2539
2540
2541
2542
2543
2544
2545
2546
2547
2548
2549
2550
2551
2552
2553
2554
2555
2556
2557
2558
2559
2560
2561
2562
2563
2564
2565
2566
2567
2568
2569
2570
2571
2572
2573
2574
2575
2576
2577
2578
2579
2580
2581
2582
2583
2584
2585
2586
2587
2588
2589
2590
2591
2592
2593
2594
2595
2596
2597
2598
2599
2600
2601
2602
2603
2604
2605
2606
2607
2608
2609
2610
2611
2612
2613
2614
2615
2616
2617
2618
2619
2620
2621
2622
2623
2624
2625
2626
2627
2628
2629
2630
2631
2632
2633
2634
2635
2636
2
```

EduCRM / **Phiếu học phí** Xin chào, Quản trị viên

Quản lý Phiếu học phí Xuất CSV Thùng rác + Tạo phiếu

Tổng 30 phiếu

Tìm mã phiếu, khóa học, tên học viên...

 Từ mm/dd/yyyy Đến mm/dd/yyyy

☐	MÃ PHIẾU	HỌC VIÊN	KHÓA HỌC	HỌC PHÍ	TRẠNG THÁI	HÀNH ĐỘNG
☐	ORD-2026-9001	Nguyễn Văn An	IELTS Foundation	3.500.000 đ	Paid	Hóa đơn Sửa Xóa
☐	ORD-2026-9002	Võ Thị Hoa	Tiếng Nhật N5	9.000.000 đ	Paid	Hóa đơn Sửa Xóa
☐	ORD-2026-9003	Đỗ Quang Minh	Lập trình Web	6.500.000 đ	Paid	Hóa đơn Sửa Xóa
☐	ORD-2026-9004	Trần Thị Bích	IELTS Advanced	4.200.000 đ	Paid	Hóa đơn Sửa Xóa
☐	ORD-2026-9005	Mai Thị Trang	Data Science	7.800.000 đ	Paid	Hóa đơn Sửa Xóa
☐	ORD-2026-0025	Lâm Văn Phong	IELTS Foundation	3.500.000 đ	Pending	Hóa đơn Sửa Xóa
☐	ORD-2026-0020	Tạ Thị Anh	Lập trình Web	6.500.000 đ	Cancelled	Hóa đơn Sửa Xóa
☐	ORD-2026-0015	Cao Văn Tuấn	Thiết kế đồ họa	12.000.000 đ	Refunded	Hóa đơn Sửa Xóa
☐	ORD-2026-0010	Ngô Thị Nga	IELTS Advanced	4.200.000 đ	Paid	Hóa đơn Sửa Xóa
☐	ORD-2026-0005	Hoàng Minh Đức	Data Science	7.800.000 đ	Pending	Hóa đơn Sửa Xóa

Trang 1/3 - 10/trang

Figure 10: Module B — danh sách Phiếu học phí: JOIN sang leads hiển thị tên học viên, hiển thị mã phiếu / học phí / trạng thái (T22).

EduCRM / **Lead** Xin chào, Quản trị viên

Thêm Lead mới « Quay lại

Không thể tạo lead. Vui lòng kiểm tra lại.

Họ tên * Email *

Số điện thoại * Khóa học *

Nguồn Trạng thái

Ghi chú

Figure 11: Duplicate handling: tạo lead với email đã tồn tại trong seed -> lỗi thay vì hiển thị "Email này đã tồn tại trong hệ thống." giữ nguyên input, không lo SQLSTATE (T21, T23).

1.14 Search / Pagination / Sort an toan (T24, T25)

URL list dung tham so: `q` (tu khoa), `status` (filter), `sort`, `direction`, `page`.
`LeadService::list()` chuan hoa input an toan:

Listing 17: `app/Services/LeadService.php` — `list()` (pagination + whitelist)

```
if (!in_array($sort, self::SORTABLE, true)) $sort = 'created_at';
// whitelist cot
$dir = strtolower($dir) === 'asc' ? 'asc' : 'desc';
// whitelist direction
if ($status !== '' && !in_array($status, config('lead_statuses', []), true)) $status = '';

$total = $this->repo->countFiltered($q, $status);
$totalPages = max(1, (int) ceil($total / $perPage));
if ($page < 1) $page = 1; // clamp page am / 0 -> 1
if ($page > $totalPages) $page = $totalPages; // clamp page qua lon -> totalPages
$offset = ($page - 1) * $perPage;
```

Ket qua test (so 25 lead, 10/trang -> 3 trang):

- `q=Tran` -> tra 2 dong dung tu khoa; `q=ZZZNOMATCH` -> "Khong co lead nao khop".
- `page=-5` -> Trang 1/3; `page=9999` -> Trang 3/3 (clamp dung).
- `sort=full_name&direction=asc` -> HTTP 200, sap xep dung.
- **Sort nguy hiem** `sort=id DESC; DROP TABLE leads; - &direction=hacker` -> HTTP 200, he thong dung sort mac dinh `created_at DESC`, bang leads van con nguyen (khong chay SQL nguy hiem).

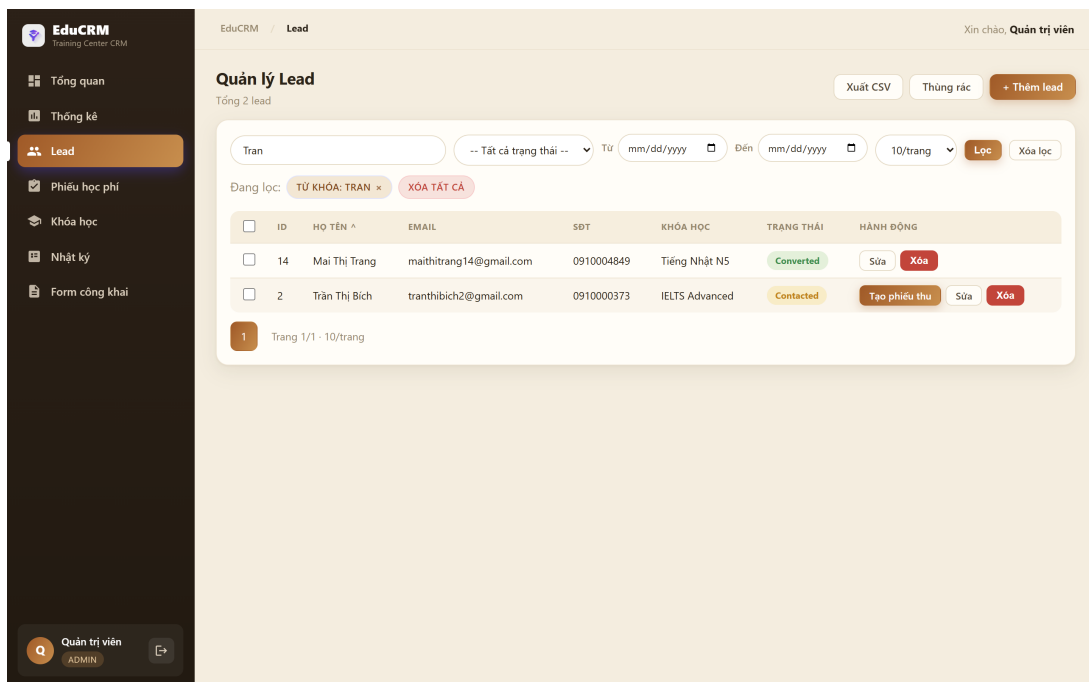


Figure 12: Search + sort an toan: `?q=Tran&sort=full_name&direction=asc` -> tra 2 dong dung tu khoa, sap xep tang dan theo Ho ten, Trang 1/1 (T24, T25).

Figure 13: Form sửa Lead (GET /leads/edit?id=1): dữ liệu cũ được đổ sẵn vào mọi field, submit qua POST /leads/update (CRUD Update).

1.15 Health JSON, 404/405 và Safe error + logging (T26–T28)

GET /health tra JSON trạng thái app/db:

Listing 18: GET /health (DB up) — output thực tế

```
{
  "status": "ok",
  "app": "EduCRM",
  "domain": "Training Center CRM",
  "database": "up",
  "php_version": "8.2.12",
  "timestamp": "2026-06-10T17:54:00+02:00"
}
```

Production safe error: config/app.php đặt debug=false. Khi DB hỏng, Front Controller bắt Throwable, ghi log chi tiết vào storage/logs/app.log và chỉ hiện trang 500 an toàn cho user — không lộ SQLSTATE / tên bảng / đường dẫn / stack trace.

Listing 19: public/index.php — xử lý lỗi an toàn

```
try {
    $router->dispatch($method, $path);
} catch (\Throwable $ex) {
    log_app('error', $ex->getMessage() . ' @ ' . $ex->getFile() . ':' .
        $ex->getLine());
    if ($debug) { /* dev: hiển thị chi tiết */ }
    else { render_error(500, '500'); } // production: trang an toan
}
```

Test thực tế khi đổi config/database.php sang database sai:

- GET /health -> HTTP 503, JSON {status:degraded, database:down}, không có SQLSTATE.
- GET /leads -> HTTP 500, trang "Đã có lỗi xảy ra"; grep SQLSTATE=0, path=0, ten bang=0.
- Log ghi: ERROR: SQLSTATE[HY000] [1049] Unknown database ... @ Database.php:50 (chỉ server-side thay).

404/405: GET /unknown-page -> 404 "Không tìm thấy trang"; POST /health -> 405 kèm header Allow: GET.

```

Pretty-print ☐
{
  "status": "ok",
  "app": "EduCRM",
  "domain": "Training Center CRM",
  "database": "up",
  "php_version": "8.2.12",
  "timestamp": "2026-07-02T10:50:11+02:00"
}

```

Figure 14: GET /health tra JSON trạng thái app/db (database up) (T26).

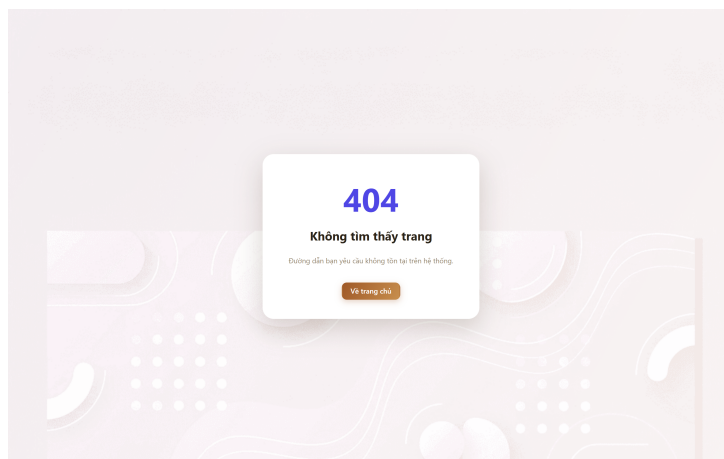


Figure 15: Route không tồn tại (GET /nope) -> trang 404 "Không tìm thấy trang" (T27). 405 + Allow và trang 500 an toàn được mô tả ở phần code/log ở trên (T28).

1.16 EXPLAIN / index (T29)

Em chạy EXPLAIN that trong MariaDB CLI cho 3 dạng query tiêu biểu: (1) list leads loc status + sort created_at, (2) lookup theo UNIQUE, (3) orders JOIN leads. Kết quả (bảng EXPLAIN canh cột day du) ở Hình dưới:

```
C:\xampp\htdocs\PHP\Lab06\EduCRM> C:\xampp\mysql\bin\mysql.exe -u root training_center_crm

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 84
Server version: 10.4.32-MariaDB mariadb.org binary distribution

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [training_center_crm]> EXPLAIN SELECT id, full_name, email, phone, course, source, status, note, created_at
-> FROM leads WHERE deleted_at IS NULL AND status='new' ORDER BY created_at DESC LIMIT 10\G
+-----+
| id | select_type | table | type | possible_keys | key | key_len | ref | rows | Extra |
+-----+
| 1 | SIMPLE | leads | ref | idx_leads_status,idx_leads_deleted | idx_leads_status | 3 | const | 12 | Using index condition; Using where; Using filesort |
+-----+
1 row in set (0.001 sec)

-- Loc status dùng index idx_leads_status (type=ref, key != NULL) -> không quét toàn bảng.

MariaDB [training_center_crm]> EXPLAIN SELECT * FROM leads WHERE email_active='nguyenvanai@gmail.com';
+-----+
| id | select_type | table | type | possible_keys | key | key_len | ref | rows | Extra |
+-----+
| 1 | SIMPLE | leads | const | uq_leads_email_active | uq_leads_email_active | 603 | const | 1 | |
+-----+
1 row in set (0.000 sec)

-- Chong trung email qua UNIQUE(email_active) [migration M1 soft-delete]: type=const -> tra cuu O(1).

MariaDB [training_center_crm]> EXPLAIN SELECT o.id, o.order_code, l.full_name FROM orders o
-> JOIN leads l ON l.id=o.lead_id WHERE o.deleted_at IS NULL AND o.status='paid'
-> ORDER BY o.created_at DESC LIMIT 10;
+-----+
| id | select_type | table | type | possible_keys | key | key_len | ref | rows | Extra |
+-----+
| 1 | SIMPLE | o | ref | idx_orders_status,idx_orders_lead_id,idx_orders_deleted | idx_orders_status | 1 | const | 11 | Using index condition; Using where; Using filesort |
| 1 | SIMPLE | l | eq_ref | PRIMARY | PRIMARY | 4 | training_center_crm.o.lead_id | 1 | |
+-----+
2 rows in set (0.001 sec)

-- Bang o dung idx_orders_status (ref); JOIN sang leads qua PRIMARY (eq_ref, 1 row) -> không full scan.

MariaDB [training_center_crm]> quit
Bye
```

Figure 16: Kết quả EXPLAIN chạy that trong MariaDB CLI (mysql.exe -u root training_center_crm): (1) list leads loc status dùng idx_leads_status (type=ref); (2) lookup UNIQUE email_active type=const; (3) orders JOIN leads: o=ref idx_orders_status, l=eq_ref PRIMARY (T29).

Nhan xét tung query:

- **List leads (loc status + sort created_at):** key = idx_leads_status (không NULL), type=ref -> MySQL dùng index để loc status thay vì quét toàn bảng (rows=12). Using filesort xuất hiện do sort theo created_at khác cột loc; vì bảng nhỏ chấp nhận được, bảng lớn có thể thêm composite index (status, created_at) để bỏ filesort.
- **Lookup UNIQUE email_active:** type=const, key=uq_leads_email_active, rows=1 -> tra cứu trung email gần như O(1). **Lưu ý:** do migration M1 (soft delete F2), rang bước chong trung chuyển từ UNIQUE(email) sang **cột sinh** email_active = IF(deleted_at IS NULL, email, NULL) + UNIQUE(email_active) — nên bạn ghi trong thùng rác không còn chiếm unique, van chong trung dùng khi tạo lead mới.
- **Orders JOIN leads (status=paid + sort):** bảng o dùng idx_orders_status (type=ref); JOIN sang leads qua khóa chính (eq_ref, 1 row) — không có full table scan.

1.17 GitHub / README (T30)

Source được quản lý bằng Git, đây lên GitHub kèm README đầy đủ (cách tạo DB, chạy server, tài khoản demo, danh sách route, cấu trúc folder, lưu ý debug/prod).

- Repository: <https://github.com/lphhien112-gif/PHP->
- Thu muc: PHP-Lab06/EduCRM/

1.18 Bang route day du

Method	URL	Controller@Action
GET	/	(redirect dashboard / public form)
GET	/login	AuthController@loginForm
POST	/login	AuthController@handleLogin
POST	/logout	AuthController@logout
GET	/dashboard	DashboardController@index
GET	/public-leads/create	PublicLeadController@create
POST	/public-leads	PublicLeadController@store
GET	/leads	LeadController@index
GET	/leads/create	LeadController@create
POST	/leads/store	LeadController@store
GET	/leads/edit?id=	LeadController@edit
POST	/leads/update	LeadController@update
POST	/leads/delete	LeadController@delete (admin)
GET	/orders	OrderController@index
GET	/orders/create	OrderController@create
POST	/orders/store	OrderController@store
GET	/orders/edit?id=	OrderController@edit
POST	/orders/update	OrderController@update
POST	/orders/delete	OrderController@delete (admin)
GET	/health	HealthController@index
ANY	(khong ton tai)	Router -> 404
(sai method)	(route ton tai)	Router -> 405 + Allow

2 Checklist task T01–T30 va Test Result TC01–TC25

2.1 Checklist task nho T01–T30

Ma	Task	Trang thai
T01	Setup moi truong (PHP 8.2.12, MySQL, curl, Git)	✓
T02	Tao project dung cau truc (public, config, app/Core, Controllers, Services, Repositories, Views, database, storage/logs)	✓
T03	Front Controller + Router (entry point duy nhat, 404/405)	✓
T04	Session cookie setup (HttpOnly, SameSite, Secure) truoc session_start	✓
T05	Helpers: e, redirect, render, partial, flash/get_flash, old, require_login	✓
T06	Layout/Partial dung chung (nav, flash), view con khong lap header/footer	✓
T07	Form cong khai secure: trim, validate server-side, old input	✓
T08	PRG sau submit hop le (F5 khong tao trung)	✓
T09	Honeypot + rate limit theo session	✓
T10	Login sai bao loi / dung redirect dashboard	✓
T11	session_regenerate_id(true) sau login	✓
T12	Timeout + logout sach (xoa session data, cookie, destroy)	✓
T13	Schema: users + 2 bang nghiep vu, PK, UNIQUE, INDEX, timestamp	✓
T14	Seed: tai khoan demo + >= 20 dong/module (38 leads + 30 orders + 8 courses)	✓
T15	PDO chuan (utf8mb4, EXCEPTION, FETCH_ASSOC, EMULATE=false)	✓
T16	Repository prepared statement (khong noi input vao SQL)	✓
T17	Service layer (validate, pagination, duplicate)	✓
T18	Controller mong (chi request -> service -> render/redirect)	✓
T19	View an toan (escape e() moi output)	✓
T20	Module A (leads) CRUD day du, POST cho store/update/delete	✓
T21	Module A duplicate (email) bao loi than thien, khong lo SQLSTATE	✓
T22	Module B (orders) CRUD day du theo rule riêng	✓
T23	Module B duplicate (order_code) bao loi dung field	✓
T24	Search/pagination/sort (q/page/sort/direction); xu ly page xau	✓
T25	Sort nguy hiem -> sort mac dinh, khong loi SQL	✓
T26	Health JSON (app/database status)	✓
T27	404 (/unknown) va 405 (POST /health)	✓

Ma	Task	Trang thai
T28	Production safe error (debug=false không lo SQL-STATE/path)	✓
T29	EXPLAIN query list/filter/sort + nhận xét index	✓
T30	GitHub + README (DB, route, demo account, ảnh)	✓

2.2 Bang Test Result TC01–TC25

Tất cả test được chạy bằng `curl` trên server `127.0.0.1:8106` và kiểm chứng trong database. Các kết quả thực tế ghi giá trị quan sát được.

Ma	Cách test	Kết quả mong đợi	Kết quả thực tế	P/F
TC01	GET /login	Form login hiện, không cần session	HTTP 200, form login hiện thì	✓
TC02	Login sai mật khẩu	Lỗi than thì, không tạo session	HTTP 302 -> /login, log "Login failed", không có session user	✓
TC03	Login đúng	Redirect /dashboard, có session, flash 1 lần	HTTP 302 -> /dashboard, dashboard 200	✓
TC04	GET /dashboard chưa login	Redirect /login	HTTP 302 -> /login	✓
TC05	Logout	Destroy session, không vào dashboard	HTTP 302 -> /login; sau đó /dashboard -> 302 /login	✓
TC06	Timeout phiên	Không hoạt động quá hạn -> login lại	require_login() so sánh last_activity > 1800s -> redirect /login	✓
TC07	Public form thiếu field	Lỗi cảnh field, giữ old input	HTTP 302, 4 field-error, old input "bademail" giữ lại	✓
TC08	Public form honeypot	Field an có data -> tu chôi	HTTP 302; leads count trước=25 sau=25 (không insert)	✓
TC09	Public form hop le	Redirect PRG, flash, F5 không trùng	HTTP 302 (PRG); DB row status=new, source=website	✓
TC10	Module A create thiếu field	Không lưu, lỗi dung field	HTTP 302, 4 field-error, không insert	✓
TC11	Module A create hop le	Redirect list, flash, DB có dòng mới	HTTP 302 -> /leads, row mới	✓
TC12	Module A duplicate email	Lỗi than thì, không lo SQLSTATE	HTTP 302 -> /leads/create, "Email này đã tồn tại trong hệ thống."	✓
TC13	Module A edit/update	Form có data cũ, update redirect list	GET edit 200 có email cũ; POST update 302, DB cập nhật	✓
TC14	Module A delete bằng POST	Xoá thành công, GET delete không được	GET /leads/delete -> 405; POST delete -> 302, row=0	✓
TC15	Module B create hop le	Redirect list, flash	HTTP 302 -> /orders, row mới	✓
TC16	Module B duplicate order_code	Lỗi dung field	HTTP 302 -> /orders/create, "Mã phiếu này đã tồn tại."	✓
TC17	Search /leads?q=Tran	Chỉ hiện data khớp	q=Tran -> 2 dòng; q=ZZZ -> "Không có lead nào khớp"	✓
TC18	Page am / qua lón	Chuan hoa ve 1 hoac totalPages	page=-5 -> Trang 1/3; page=9999 -> Trang 3/3	✓
TC19	Sort hop le	Sort dung cot/direction	sort=full_name&direction=asc -> 200, sắp dung	✓

Ma	Cach test	Ket qua mong doi	Ket qua thuc te	P/F
TC20	Sort nguy hiem	Khong chay SQL nguy hiem, sort mac dinh	sort="id DESC; DROP TABLE..." -> 200, bang con nguyen	✓
TC21	GET /health	JSON status app/db	HTTP 200, status:ok, database:up	✓
TC22	POST /health	405 Method Not Allowed	HTTP 405, header "Allow: GET"	✓
TC23	GET /unknown	404 Not Found	HTTP 404, "Khong tim thay trang"	✓
TC24	DB loi (production)	Khong lo SQL-STATE/path; log/safe msg	/health 503 down; /leads 500 an toan; SQL-STATE=0; log ghi chi tiet	✓
TC25	EXPLAIN query list	Query co index khi filter/sort	key=idx_leads_status (khong NULL); email_active -> uq_leads_email_active (const)	✓

Tong ket: 25/25 test case PASS.

3 Cau 2: Problem Solving

3.1 Front Controller & Router

Trong EduCRM, **mọi request đều đi qua public/index.php**. Router map METHOD + PATH -> Controller@Action bằng cách lưu danh sách route và số khớp tuần tự (ví dụ POST /leads/store -> LeadController@store). Nếu mỗi file PHP xử lý một URL riêng, khi thêm **auth** sẽ phải thêm `require_login()` vào từng file; thêm **middleware** (logging, CSRF) phải sửa hàng chục chỗ; **404/405** không đồng nhất. Với Front Controller, em chỉ cần thêm một dòng trước `dispatch()` là áp dụng cho toàn bộ route, và Router phân biệt 404/405 tập trung một nơi.

3.2 Secure form

Form công khai /public-leads kiểm tra server-side trong `LeadService::validate()`: `trim` + `required`, email bằng `filter_var(...FILTER_VALIDATE_EMAIL)`, phone bằng regex `/0{9,10}$`, course phải thuộc whitelist khoa học, giới hạn độ dài. Không thể chỉ dựa vào `required/type=email` của HTML vì attacker có thể bỏ qua trình duyệt (dùng curl/Postman) gửi thẳng POST, hoặc sửa DOM; validate HTML chỉ là trải nghiệm người dùng, **không phải biện pháp bảo mật**.

3.3 PRG Pattern

Sau POST thành công, EduCRM **redirect (302)**: `/leads/store` -> `/leads`, `/public-leads` -> `/public-leads/create`. Nếu render kết quả trực tiếp trên request POST, khi user bấm **F5** trình duyệt sẽ gửi lại POST -> **tao ban ghi trung** (ví dụ tạo 2 lead/2 order giống nhau) hoặc kích hoạt lại thành toán. PRG đảm bảo F5 chỉ tải lại trang GET vô hại.

3.4 Anti-spam cơ bản

Honeypot: field ẩn website (CSS đưa ra ngoài màn hình). Người thật không điền, **bot** thường điền hết field -> bị chặn (giả vờ thành công để bot không biết). **Rate limit theo session**: tôi đã 5 submit / 300 giây, không gửi liên tục. Giới hạn: honeypot vô hiệu với bot thông minh; rate limit theo session để bị vượt bằng cách xóa cookie / đổi session. Khi cần mạnh hơn nên nâng cấp **CSRF token** (đã có trong project cho form nội bộ), **reCAPTCHA**, và **rate limit theo IP** ở tầng web server.

3.5 Session/login flow

Flow trong project: `AuthService::attempt()` validate input -> `password_verify` với hash bcrypt -> `AuthService::login()` gọi `session_regenerate_id(true)` -> lưu `user/role/login_at/last_activity` -> `flash` -> `redirect /dashboard`. Nếu không regenerate id sau login, kẻ tấn công đã biết trước session id (do gán cho nạn nhân từ lúc chưa đăng nhập) có thể **session fixation**: dùng lại chính session id đó để chiếm phiên sau khi nạn nhân đăng nhập.

3.6 Logout, timeout va cookie flags

Logout xoa `$_SESSION = []`, `setcookie` cookie session ve qua khu (xoa cookie), va `session_destroy()`. Timeout: `require_login()` so sanh `time() - last_activity > 1800` -> xoa session + redirect `/login`. **HttpOnly** ngan JavaScript doc cookie (giam danh cap session qua XSS); **SameSite=Lax** ngan gui cookie trong request cross-site (giam CSRF); **Secure** (bat khi HTTPS) ngan cookie di qua HTTP khong ma hoa.

3.7 Remember me

EduCRM khong luu password vao cookie. **Khong duoc** luu password vi cookie nam o may client, de bi doc/danh cap (XSS, may dung chung) -> lo mat khau truc tiep. Neu lam that, em se sinh mot **token ngau nhien** (selector + validator), luu hash cua validator trong DB kem `user_id` va `expires_at`; cookie chi chua token; khi quay lai, so hash token, hop le thi tao phien moi va **xoay token** (rotation). Token co the thu hoi va het han, an toan hon luu credential.

3.8 Database schema

Em thiet ke `users` (nguoi dang nhap), `leads` (lead tu van) va `orders` (phieu hoc phi) vi do la 3 thuc the cot loi cua CRM trung tam dao tao. **Primary key**: id moi bang. **Foreign key**: `orders.lead_id` -> `leads.id` (ON DELETE CASCADE — xoa lead thi phieu lien quan cung xoa). **Unique**: `users.username`, `leads.email`, `orders.order_code`. **Index**: `idx_leads_status`, `idx_leads_course`, `idx_orders_status`, `idx_orders_lead_id`, `*_created_at` (ho tro filter/sort). **Timestamp**: `created_at`, `updated_at` (auto cap nhat).

3.9 Prepared statements

Chon 1 INSERT va 1 SELECT trong LeadRepository:

- INSERT: `INSERT INTO leads (...) VALUES (:full_name, :email, ...)` — cau lenh SQL co dinh, du lieu nguoi dung truyen qua mang `execute([':email' => $data['email'], ...])`.
- SELECT: `... WHERE (full_name LIKE :q_name OR email LIKE :q_email ...)` — tu khoa tim kiem bind qua placeholder `:q_name`.

SQL command va user input duoc **tach hoan toan**: voi `EMULATE_PREPARES=false`, driver gui cau lenh va tham so rieng den MySQL; input luon duoc coi la **du lieu**, khong bao gio la **cu phap SQL** -> chong SQL Injection triet de (vi du nhap `' OR 1=1` - chi thanh chuoi tim kiem vo hai).

3.10 Unique constraint & duplicate handling

Chi kiem tra trung bang PHP (SELECT truoc roi INSERT) la chua du vi co **race condition**: hai request gan nhu dong thoi cung SELECT thay "chua ton tai" roi cung INSERT -> tao 2 ban ghi trung. **UNIQUE constraint** o DB la **rang buoc nguyen tu o tang luu tru**: chi mot INSERT thanh cong, cai con lai bi tu choi (errno 1062), va EduCRM bat thanh `DuplicateRecordException` -> thong bao than thien. Day la "nguồn sự thật" cuối cùng chong trung.

3.11 Search/pagination/sort safe

URL list dung q, status, sort, direction, page. Xu ly: page ep (int), < 1 -> 1, > totalPages -> totalPages; sort phai thuoc whitelist SORTABLE (neu khong -> created_at); direction chi nhan asc/desc; status phai thuoc whitelist. Sort nguy hiem (id DESC; DROP TABLE...) khong nam trong whitelist nen bi thay bang mac dinh -> **khong bao gio ghep chuoi nguy hiem vao ORDER BY**. Da test: bang leads van con nguyen sau khi thu.

3.12 Index & EXPLAIN

Query `SELECT ... FROM leads WHERE status='new' ORDER BY created_at DESC LIMIT 10; EXPLAIN` cho key=idx_leads_status, type=ref -> co dung index loc status (khong full scan). Neu key=NULL tren bang lon (vi du chua co index hoac dieu kien khong sargable), em se: them **index** cho cot loc, tao **composite index** (status, created_at) de vua loc vua sort (bo Using filesort), va tranh ham bao quanh cot trong WHERE.

3.13 MVC dung trach nhien

Trong EduCRM: **Controller** doc request, goi Service, render/redirect (vi du LeadController::store() chi goi `$this->leads->create($_POST)` roi redirect — **khong co dong SQL nao**). **Service** giu rule (validate, pagination, duplicate). **Repository** chua toan bo SQL prepared. **View** chi hien thi va escape: vi du leads/index.php chi co `<?= e($r['email']) ?>`, **khong he query DB**. Em kiem chung bang grep: Controllers/Views khong co ->prepare/->query; Repositories/Services khong doc `$_POST/$_GET`.

3.14 Layout/Partial & XSS

Dung layout/partial (layouts/main.php, partials/nav.php, partials/flash.php) de tranh lap header/menu/footer o nhieu view — sua mot noi ap dung toan bo, giam loi va de bao tri. Du lieu tu DB/user duoc escape bang e() (htmlspecialchars voi ENT_QUOTES) **ngay tai View** truoc khi in ra HTML, chong XSS (vi du ten lead chua `<script>` se thanh text vo hai).

3.15 Dev/prod error message

Production khong nen hien `$e->getMessage()`, SQLSTATE hay stack trace vi chung lo **cau truc he thong** (ten bang, cot, duong dan file, phien ban) — giup attacker do tham. EduCRM: khi loi, Front Controller `log_app('error', ...)` ghi chi tiet vao storage/logs/app.log (server-side), con user chi thay trang 500 "Da co loi xay ra" (khi debug=false). Da kiem chung: grep SQLSTATE tren HTML tra ve user = 0.

3.16 404 vs 405

Vi du trong project: GET /khong-ton-tai -> **404** (Router khong tim thay path nao). POST /health -> **405** (path /health co ton tai nhung chi cho GET, kem header Allow: GET). Can phan biet vi 404 bao "tai nguyen khong ton tai" (client kiem tra lai URL), con

405 bao "sai phuong thuc" (client doi method dung) — giup client/crawler hanh xu dung va debug nhanh.

3.17 Delete bang POST

Delete/update khong nen dung GET vi GET phai **idempotent va an toan** (khong doi trang thai). Neu delete qua GET: crawler/Googlebot di theo link co the **xoa du lieu**; trinh duyet prefetch hoac tinh nang preview link co the kich hoat; user bam nham hoac mo lai tu lich su cung xoa nham. EduCRM dung POST /leads/delete + CSRF token + xac nhan, va GET vao /leads/delete tra **405**.

3.18 Huong phat trien that

Voi bai toan trung tam dao tao, em uu tien: **(1) CSRF** (da co — bao ve moi form POST); **(2) Role permission** (da co o muc co ban — admin xoa, staff khong; mo rong them quyen chi tiet); **(3) Logging/audit trail** (ai sua lead/order nao, khi nao — quan trong voi du lieu khach hang va tien hoc phi); **(4) Transaction** (da dung khi tao order; mo rong khi them order_items/payment); **(5) Soft delete** (deleted_at de khoi phuc du lieu khach hang); sau do moi den **tests, API** va **Docker**. Ly do: du lieu lead/order gan voi tien va khach hang nen **toan ven va truy vet** duoc uu tien hang dau.

4 Tinh nang mo rong nang cao va giao dien hien dai

Sau khi hoan thanh yeu cau bat buoc, em phat trien them cac tinh nang nang cao (F1–F5) theo huong mot CRM thuc te, kem mot dot **redesign giao dien** theo phong cach **admin sidebar hien dai**. Tat ca deu duoc **kiem thu live** tren database that (MariaDB) bang trinh duyet va curl; bang ket qua o cuoi muc.

4.1 F1 — Chuyen Lead thanh Phieu thu (transaction)

Tu mot lead trang thai **qualified/contacted**, nut “Tao phieu thu” mo form order da dien san (ma phieu goi y, khoa hoc, hoc vien). Khi luu, trong **mot transaction**: INSERT order + UPDATE lead sang **converted** + ghi audit; neu trung **order_code** thi rollBack ca hai. Guard nguyen tu o muc SQL: UPDATE ... WHERE id=:id AND status NOT IN ('converted', 'lost') de chong double-submit.

Figure 17: F1: form chuyen lead sang phieu thu (prefilled). Da verify live: lead 3 -> converted, order ORD-2026-9678 tao moi (orders 25->26).

4.2 F2 — Soft delete + Thung rac (Restore)

Xoa = danh dau **deleted_at** (khong DROP); moi truy van doc deu loc **deleted_at IS NULL**. Trang /leads/trash (chi admin) cho **khoi phuc** hoac **xoa vinh vien**. Em cung sua mot bug do dot review phat hien: **UNIQUE(email)** cu van chan ban ghi da xoa mem, nen em chuyen sang **cot sinh email_active = IF(deleted_at IS NULL, email, NULL) + UNIQUE(email_active)** (M1) — ban ghi trong thung rac khong con chiem unique.

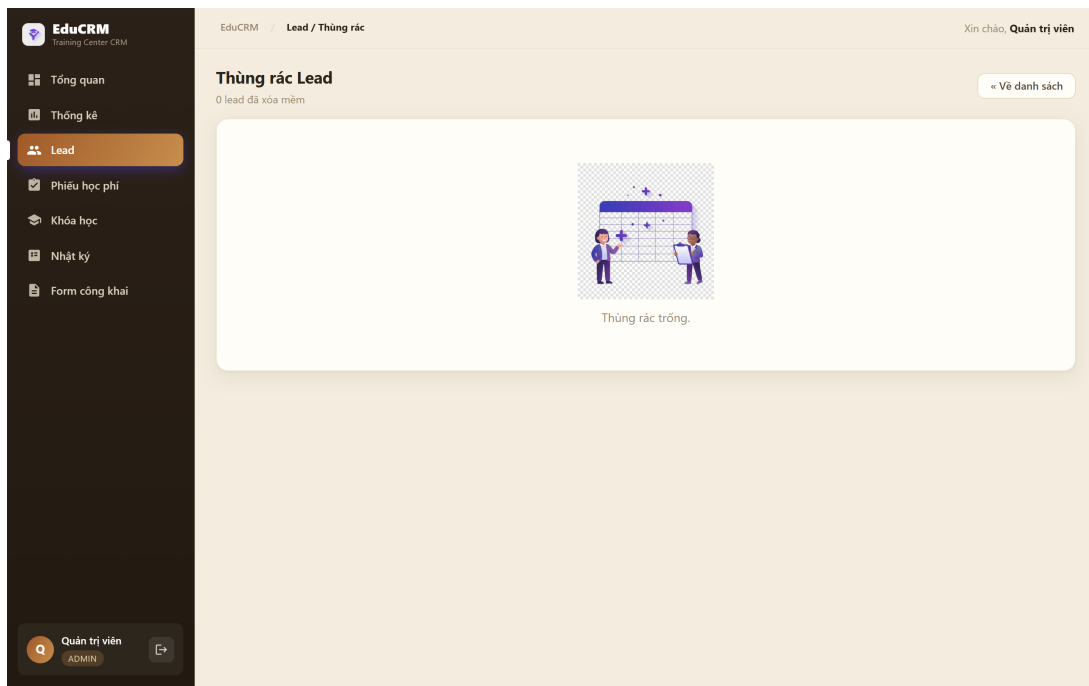


Figure 18: F2: thùng rác liệt kê ban ghi đã xóa mềm, có Khôi phục / Xóa vĩnh viễn (chỉ admin). Đã verify: xóa -> trash -> restore.

4.3 F3 — Audit log (nhật ký hoạt động)

Bảng `activity_logs` ghi ai làm gì lúc nào (create/update/delete/restore/convert/ login/logout/login_failed), không lưu PII. Trang `/audit` chỉ admin (staff bị redirect về dashboard — đã verify server-side).

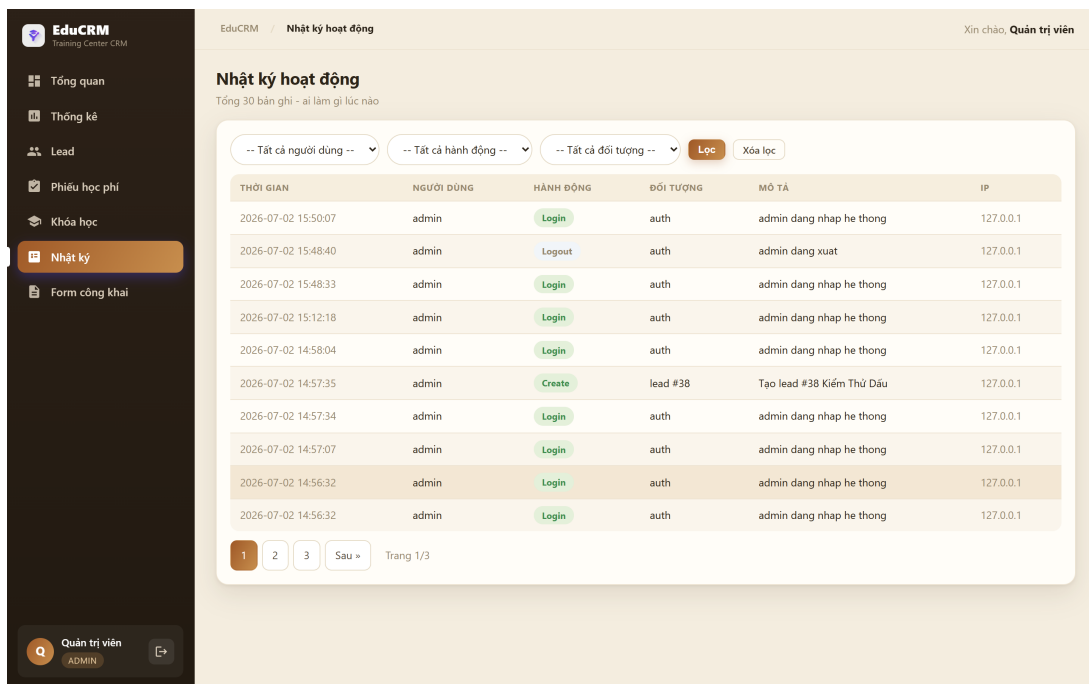


Figure 19: F3: nhật ký hoạt động, lọc theo user/action/entity, phân trang; chỉ admin truy cập.

4.4 F4 — Export CSV an toan

/leads/export va /orders/export stream CSV theo dung filter hien tai, co Content-Disposition: attachment, **UTF-8 BOM** (mo dung trong Excel), va chong **CSV injection** (them dau nhảy đơn trước o bắt đầu bang = + - @). Da verify: Content-Type: text/csv, BOM EF BB BF, 26 dòng dung filter.

4.5 F5 — Dashboard analytics

Dashboard bổ sung 4 khối trực quan về bảng CSS/SVG thuần (không dùng thư viện JS): **lead theo 14 ngày**, **phễu chuyển đổi** (new -> contacted -> qualified -> converted), **doanh thu 6 tháng** (chỉ tính paid), **Top 5 khóa học**.

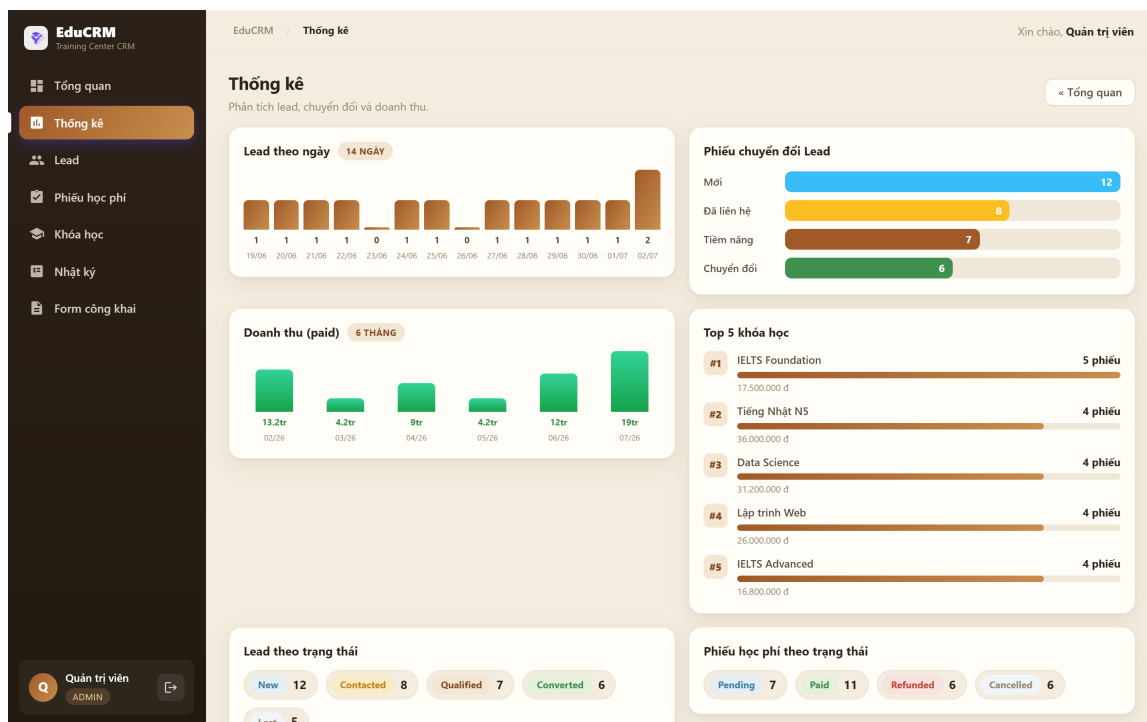


Figure 20: F5 + giao diện mới: shell sidebar admin (logo, nav có icon, user/role/logout), và 4 khối analytics với số liệu thật.

4.6 Giao diện hiện đại (redesign)

Em chuyển từ thanh top-bar sang **sidebar admin có định** (logo, nav có icon SVG, trạng thái active, user/role/logout ở đây), top bar mong + breadcrumb, thêm góc 16px + đổ bóng nhiều lớp, status pill, bảng sticky header, flash toast, và **responsive** (sidebar thu thành off-canvas drawer ở màn hình nhỏ). Toàn bộ giữ đúng kiến trúc MVC và không phá chức năng đang chạy.

4.7 Tính năng F6–F11 (CRM nâng cao)

Em phát triển tiếp một loạt tính năng nâng cao, đều kiểm thử live bằng curl và trình duyệt:

- **F6 — Login hardening:** khoa dang nhap sau nhieu lan sai (bang `login_attempts`); **remember-me** bang token — luu **hash** token trong `remember_tokens`, cookie `selector:token` (HttpOnly/SameSite), **rotate** moi lan dung, **revoke** khi logout. Tuyet doi khong luu mat khau trong cookie.
- **F7 — JSON API + Bearer token:** GET `/api/leads`, `/api/orders`, `/api/stats` chi doc, xac thuc qua header `Authorization: Bearer <token>` (so voi bang `api_tokens`); token sai/thieu tra **401**.
- **F10 — Hoa don in duoc:** GET `/orders/invoice?id=` tra trang hoa don sach (print CSS), nut “In hoa don” goi `window.print()`.
- **F11 — Role manager:** `users.role` mo rong thanh `admin/manager/ staff`,phan quyen **enforce server-side** (khong chi an nut tren giao dien).
- **F8 — Loc khoang ngay** (`created_from/created_to`) va **F9 — Bulk actions** (POST `id[]`: xoa mem / doi trang thai hang loat) cho danh sach.
- **F12 — Da dang phuong thuc tu van (Public Leads):** Hien thi 4 the (Cards) lua chon: Video Call, Chat, Dien thoai, Truc tiep truoc khi dang ky. Bo sung UI Assets cho tung the (`consult-video.png`, `consult-chat.png`, `consult-phone.png`, `consult-inperson.png`) de tang trai nghiem UI/UX.

Listing 20: GET `/api/stats` voi Bearer token hop le — tra JSON 200

```
{
  "data": {
    "leads": {
      "total": 25,
      "by_status": { "new": 5, "contacted": 5, "qualified": 4, "
        converted": 6, "lost": 5 }
    }
    // ... orders, revenue ...
  }
}
```

4.8 Module C — Quan ly Khoa hoc (CRUD + anh + phan quyen)

Ngoai hai module bat buoc (Lead, Order), em phat trien them **Module C — Quan ly Khoa hoc** (`/courses`) de danh sach khoa hoc tro thanh **nguồn dữ liệu** thay vi whitelist tinh trong config: form Lead/Order va validate deu so khop `courses.name`. Module giu dung phan lop **Controller (mong) -> Service (nghiep vu) -> Repository (SQL) -> View (escape)**.

Chuc nang day du: danh sach dang *grid* co timkiem, loc theo nhom / trang thai hien-an, sort whitelist, phan trang; **trang chi tiet** (`/courses/view`) hien mo ta + “Ban se hoc duoc gi” + **muc do su dung** (so lead quan tam, so phieu, doanh thu tinh tu cac ban ghi tham chieu ten khoa); **them / sua / xoa mem / khoi phuc / xoa vinh vien; bat-tat hien thi** (toggle) de an khoa khoi form dang ky ma khong xoa; **export CSV** theo filter; moi thao tac ghi **audit log**.

Phan quyen enforce SERVER-SIDE (khong chi an nut o giao dien), qua helper `require_can()`:

Listing 21: CourseController — kiem tra quyen o tung action (rut gon)

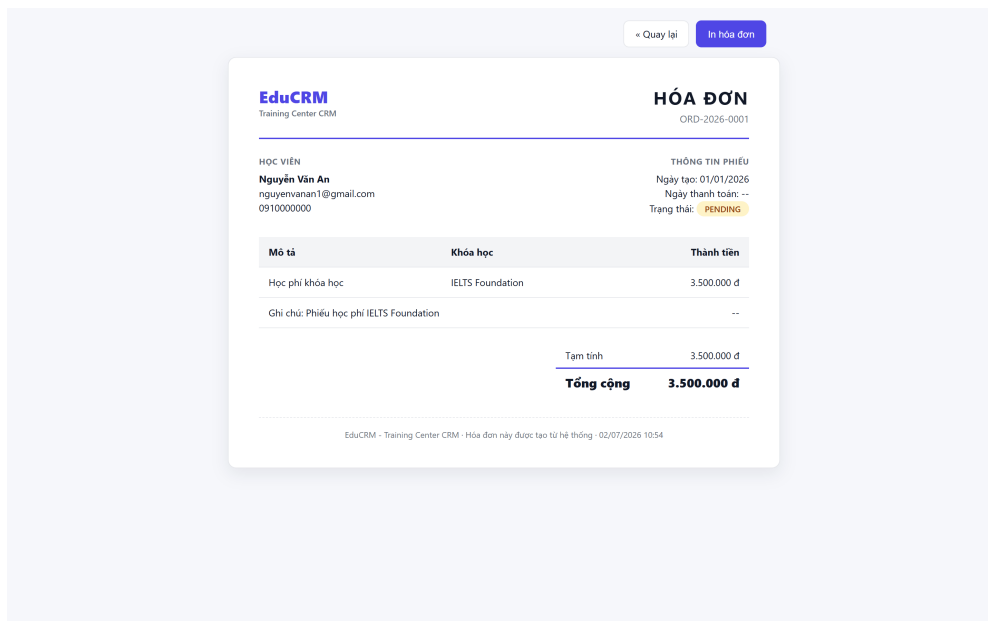


Figure 21: F10: hoa don in duoc (GET /orders/invoice?id=1) — print CSS, nút “In hoa don”, tong tien.

```
public function index() { require_login(); /* xem: moi user da dang
nhap */ }
public function store() { require_login(); require_can('
manage_courses', '/courses'); ... }
public function toggle() { require_login(); require_can('
manage_courses', '/courses'); ... }
public function forceDelete() { require_login(); require_can('
force_delete', '/courses/trash'); ... }
```

Xem danh sach/chi tiet: moi user dang nhap. Them/sua/xoa mem/khoi phuc/toggle/export: `manage_courses` (admin + manager). **Xoa vĩnh viễn**: `force_delete` (chi admin).

Validate server-side (`CourseService::validate()`): ten bat buoc, toi da 80 ky tu; `category` va `level` phai thuoc whitelist; hoc phi la so `[0..999.999.999]`; thoi luong so nguyen `[1..260]` tuan; mo ta ≤ 2000 , outcomes ≤ 3000 ky tu. **Anh minh hoa** khong upload tuy y ma **chon tu danh sach anh co san** (`course_images()`) — gia tri gui len phai nam trong whitelist do, chong chen duong dan la / injection. `slug` URL-friendly duoc **tu sinh** tu ten; trung ten/slug bat `DuplicateRecordException` thanh loi than thien theo field. (Anh danh sach grid khoa hoc xem Hình o muc QW5 phía dưới.)

4.9 Quick Wins: nang cap thong ke va trai nghiem nguoi dung

Sau dot review, em bo sung mot nhom cai tien nho nhung tang ro trai nghiem va do tin cay cua thong ke (goi la “Quick Wins”). Tat ca deu giu dung phan lop **Controller (mong) -> Service (nghiep vu) -> Repository (SQL) -> View (escape e())** va dakiem thu live tren MariaDB.

QW1 — Empty-state cho bieu do + seed du lieu ngay dong

Truoc day khi khong co du lieu, cac chart “Lead theo ngay” va “Doanh thu” ve mot loat cot 0 trong nhu bi loi. Em xu ly o **tang View**: `analytics/index.php` tinh

Thêm khóa học

Tên khóa học *

Nhóm *
-- Chọn nhóm --

Trình độ *
Cơ bản

Học phí (VND) *

Thời lượng (tuần) *
8

Ảnh minh họa
-- Không dùng ảnh --

Xem trước ảnh
Chưa chọn ảnh

Giới thiệu khóa học
Đoạn văn giới thiệu: khóa này dành cho ai, học gì, đạt được gì...

Bạn sẽ học được gì (mỗi dòng 1 ý)
 Nắm vững ngữ pháp cốt lõi
 Xây dựng từ vựng theo chủ đề
 Tự tin làm bài thi thứ

☒ Hiện khóa học này trên form lead/phiếu học phí

[Lưu khóa học](#) [Hủy](#)

Figure 22: Module C: form “Thêm khoa học” — nhóm/trình độ/học phí/thời lượng, chọn ảnh minh họa có xem trước, giới thiệu + “Bạn sẽ học được gì”, và tùy chọn hiện khoa học trên form đăng ký.

IELTS Foundation

Ngoại ngữ **Cơ bản** **Đang mở**

3.500.000 đ / khóa

Nhóm: Ngoại ngữ
Trình độ: Cơ bản
Thời lượng: 10 tuần
Học phí / tuần: 350.000 đ
Ngày tạo: 2026-07-02 14:53:03
Trạng thái: Hiện trên form đăng ký

Giới thiệu khóa học
Khóa nền tảng dành cho người mới tiếp cận IELTS hoặc còn mất gốc tiếng Anh. Bạn được củng cố ngữ pháp lõi, mở rộng từ vựng theo chủ đề và làm quen định dạng 4 kỹ năng Nghe - Nói - Đọc - Viết. Lộ trình hướng tới band 4.5-5.5, tạo nền tảng vững chắc trước khi lên trình độ cao hơn.

Bạn sẽ học được gì

- Nắm vững 12 chủ điểm ngữ pháp cốt lõi của IELTS
- Xây dựng 800+ từ vựng học thuật theo chủ đề
- Làm quen cấu trúc và cách tính điểm 4 kỹ năng
- Tự tin làm bài thi thứ đạt band 4.5-5.5

Mức độ quan tâm

6 Lead quan tâm
5 Phiếu đã tạo
3.500.000 Doanh thu đã thu (VND)

Số liệu tính từ các lead/phiếu đang tham chiếu tên khóa học này.

Figure 23: Module C: trang chi tiết /courses/view — poster, badge nhóm/trình độ/trạng thái, học phí, “Bạn sẽ học được gì”, và khối “Mức độ quan tâm” (so lead / so phiếu / doanh thu tính từ dữ liệu tham chiếu khóa học).

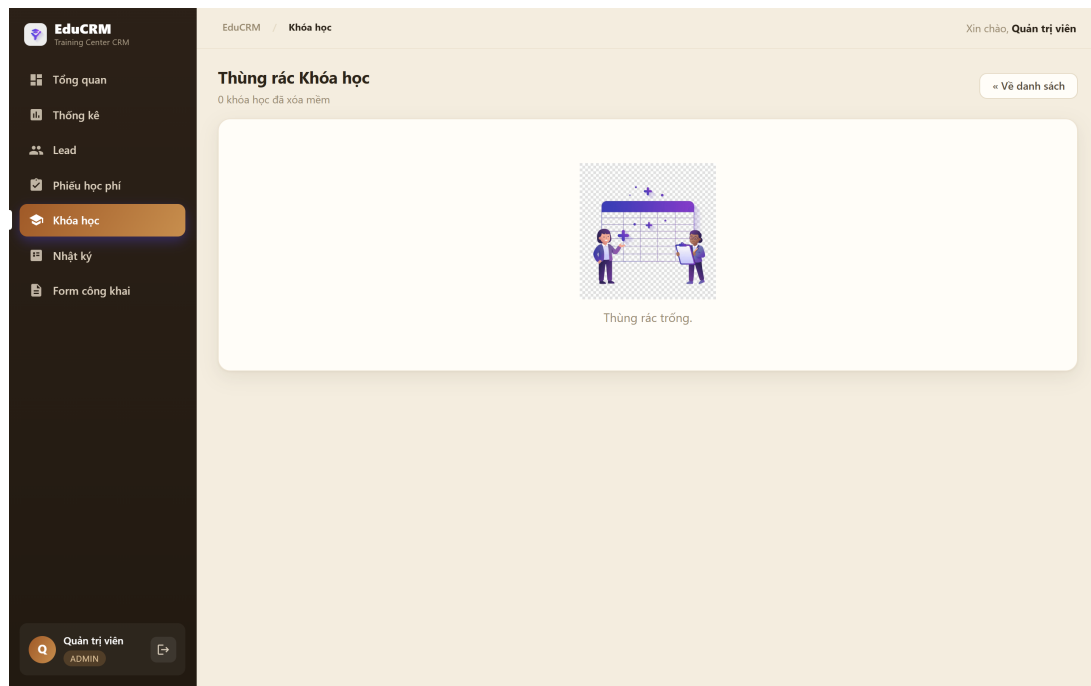


Figure 24: Module C: thùng rác khoa học (soft delete) — liệt kê khoa đã xóa mềm, cho Khôi phục / Xóa vĩnh viễn (xóa vĩnh viễn chỉ admin).

`array_sum($leadsPerDay)` và `array_sum($revenue)`, nếu ≤ 0 thì hiển thị trạng thái **empty-state** (“Chưa có lead trong 14 ngày gần đây.” / “Chưa có doanh thu đã thu trong 6 tháng gần đây.”) thay vì chart rỗng. Ở **tang Repository**, các truy vấn aggregate dùng **moc thời gian dòng** để biểu đồ luôn có dữ liệu thật:

Listing 22: StatsRepository — moc thời gian dòng (leadsPerDay / revenueLastMonths)

```
-- Lead theo N ngày gần đây (dien 0 cho ngày thiếu ở tang PHP)
WHERE deleted_at IS NULL
  AND created_at >= (CURRENT_DATE - INTERVAL :days DAY)
-- Doanh thu (paid) N tháng gần đây
WHERE deleted_at IS NULL AND status = 'paid'
  AND created_at >= (DATE_FORMAT(CURRENT_DATE, '%Y-%m-01') - INTERVAL
    :m MONTH)
```

Seed cung thêm 12 lead trong 14 ngày gần nhất + 5 phiếu paid tháng này / tháng trước với ngày tính theo `DATE_SUB(NOW(), ...)` / `CURRENT_DATE` / `LAST_DAY`, nên biểu đồ không bao giờ trong dữ liệu seed chạy bất kỳ ngày nào.

QW2 — Thống kê “Lead theo nguồn”

Bổ sung phân tích lead theo kênh (website / facebook / zalo / referral / hotline). SQL nằm ở **Repository** — `LeadRepository::countBySource()` GROUP BY source (vẫn lọc `deleted_at IS NULL` để tránh soft delete); **Service** `DashboardService::analytics()` gom vào khoa `bySource`; **View** `/analytics` vẽ khối `status-pills` có badge màu theo từng nguồn.

Listing 23: `LeadRepository::countBySource()` — SQL ở Repository

```
$rows = $this->db()->query(
```

```
'SELECT source, COUNT(*) AS total FROM leads
WHERE deleted_at IS NULL GROUP BY source'
)->fetchAll();
```

QW3 — KPI co xu huong o Dashboard

Trang /dashboard them khoi “Xu huong kinh doanh” voi 3 chi so **co ngu canh** thay vi chi so tinh: **Ty le chuyen doi** (converted / tong lead), **Ty le thanh toan** (paid / tong phieu) va **Delta doanh thu** thang nay so voi thang truoc (mui ten len/xuong, to xanh/do). Logic tinh nam trong `DashboardService::summary()`; dac biet Controller **tai dung** `leadStats / orderStats` da lay san (khong query lai DB) — dung tinh than Service nhan du lieu, khong tu di lay.

Listing 24: `DashboardService::summary()` — KPI co xu huong (rut gon)

```
$deltaPct = $prev > 0 ? (($cur - $prev) / $prev * 100) : null; //
    null neu thang truoc = 0
return [
    'conversionRate' => $leadTotal > 0 ? $converted / $leadTotal *
        100 : 0.0,
    'paymentRate'    => $orderTotal > 0 ? $paid / $orderTotal *
        100 : 0.0,
    'revenueThisMonth' => $cur, 'revenueLastMonth' => $prev,
    'revenueDeltaPct' => $deltaPct,
];
```

View chon mau/mui ten theo dau cua `revenueDeltaPct`: duong -> ▲ xanh, am -> ▼ do, khong so sanh duoc (thang truoc = 0) -> “Chua co du lieu thang truoc”.

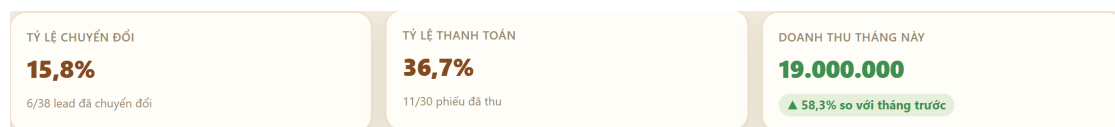


Figure 25: QW3: khoi “Xu huong kinh doanh” o /dashboard — Ty le chuyen doi, Ty le thanh toan va Delta doanh thu thang nay vs thang truoc (mui ten + mau xu huong).

QW4 — Loading skeleton va trang thai “Dang luu...”

Bo sung phan hoi truc quan khi thao tac: (1) `.skeleton` (shimmer) cho vung noi dung dang tai; (2) khi submit form, mot handler `submit` toan cuc trong `layouts/main.php` khoa nut da bam + hien spinner va doi nhan nut primary sang “Dang luu...” — chong double-submit (tao trung lead/phieu); (3) form GET (loc/tim) mo mo noi dung (`.is-filtering`) tao cam giac “dang loc”. Ky thuat quan trong: chi disabled nut sau khi submit da khoi chay (`setTimeout(..., 0)`) de gia tri cua nut van duoc gui di, va bo qua khi `event.defaultPrevented` (vd `onsubmit confirm()` bi huy) de khong ket nut.

Listing 25: `layouts/main.php` — handler submit toan cuc chong double-submit (rut gon)

```
document.addEventListener('submit', function (ev) {
    if (ev.defaultPrevented) return; // onsubmit
    confirm() bi huy
```

```

var btn = ev.submitter || form.querySelector('button[type="submit"
    "']');
if (btn.classList.contains('btn-primary')) btn.textContent = '
    Dang luu...';
btn.classList.add('is-loading');
setTimeout(function () { btn.disabled = true; }, 0); // disable
    SAU submit -> van gui gia tri nut
});

```

QW5 — Bat tieng Viet co dau toan bo giao dien (Phuong an A)

Toan bo van ban hien thi chuyen sang **tieng Viet co dau** chuan chinh ta: ten khoa hoc / nhom trong `config/app.php` (vd *Lap trinh Python* / *Tieng Nhat N5* / *Thiet ke do hoa* hien thi co dau day du trong UI), du lieu seed (ten khoa hoc, mo ta, ten lead, ghi chu), va toan bo view / service / controller / helper (tieu de, nhan, placeholder, nut, cot bang, thong bao flash/validate, nhan bieu do, empty-state). DB da `utf8mb4` nen **khong doi schema**; whitelist `courses` trong config van khop `courses.name` de validate lead/order dung. Luu y ky thuat: da go BOM 3 file layout de tranh byte rac truoac `<?php`.

Pham vi bao cao: theo quy uoc, than bao cao LaTeX **van viet ASCII khong dau**; screenshot la anh nen the hien duoc UI co dau ma khong anh huong text trong `.tex`.

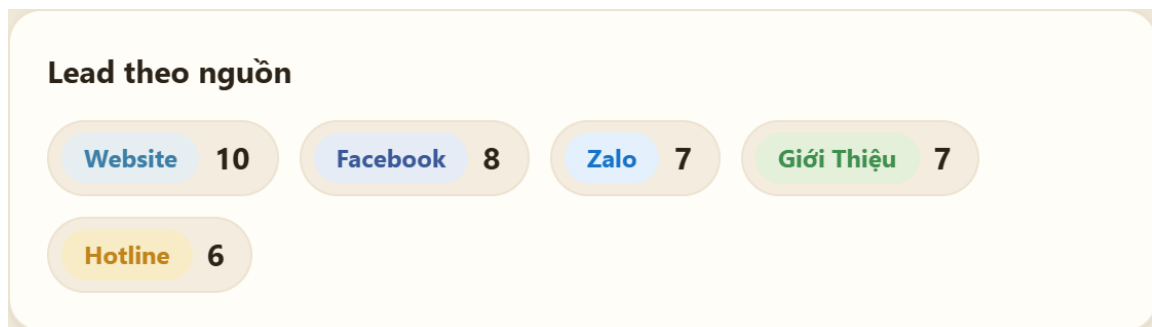


Figure 26: QW1 + QW2: trang `/analytics` co du lieu that (chart “Lead theo ngay” / “Doanh thu” khong con trong nho seed ngay dong) va khoi “Lead theo nguon” (status-pills badge mau theo kenh).

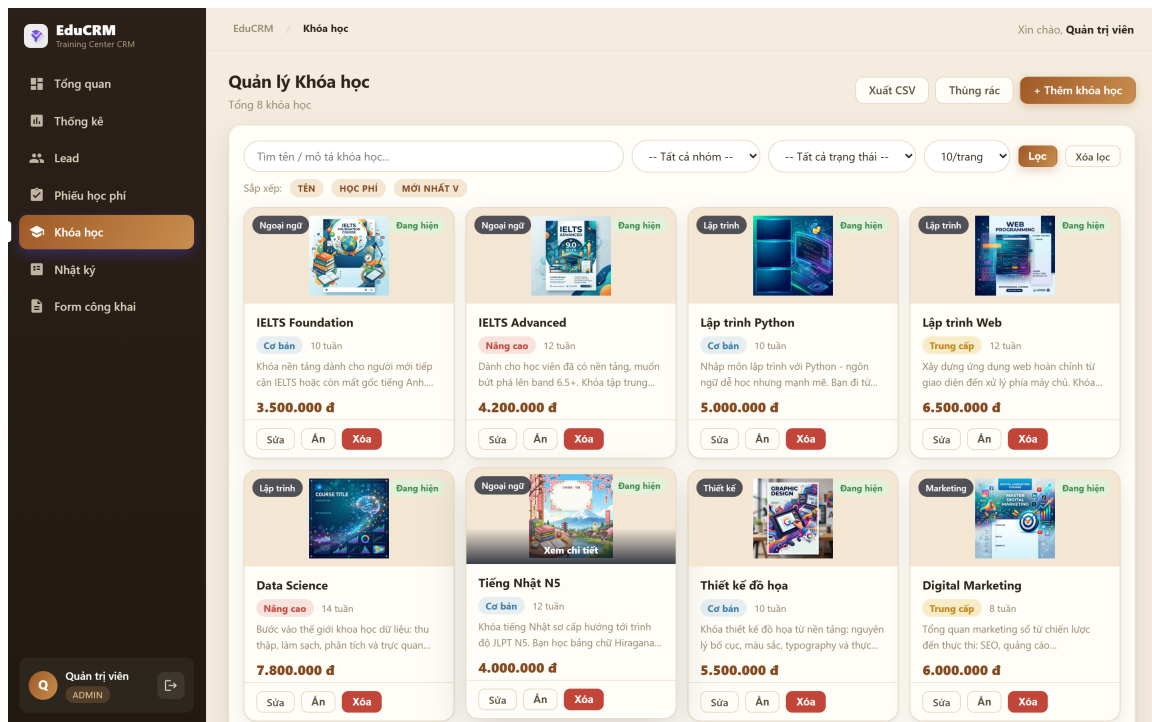


Figure 27: QW5: một màn hình thể hiện giao diện tiếng Việt có dấu đầy đủ (tiêu đề, nhan, nút, dữ liệu từ DB đều có dấu) — DB utf8mb4, không đổi schema.

4.10 Bang kiem thu tinh nang mo rong (verify live)

Ma	Cach test	Ket qua thuc te	P/F
F1 convert	Convert lead qualified (id=3), dien hoc phi, submit	Order ORD-2026-9678 tao moi; lead 3 -> converted; orders 25->26; audit convert	✓
F1 guard	Convert lai lead da converted	Bi chan, khong tao order thu hai	✓
F2 delete	Admin xoa mem lead 1	Mat khoi list, vao /trash; deleted_at set; audit delete	✓
F2 restore	Khoi phuc lead 1	deleted_at =NULL, ve list; audit restore	✓
M1 unique	Lead da xoa mem	email_active =NULL -> khong chan tao moi cung email	✓
M2 login CSRF	POST /login thieu _csrf	302 ve /login, khong dang nhap duoc	✓
F3 audit	Mo /audit	10 dong; staff -> 302 /dashboard (admin-only)	✓
F4 CSV	GET /leads/export (admin)	text/csv + attachment + BOM + 26 dong	✓
F5 analytics	Mo /dashboard	4 bieu do so that	✓
Role	Staff POST /leads/force-delete	Bi chan, lead 2 con nguyen	✓
F7 API	GET /api/leads + Bearer hop le / sai	200 JSON / 401 (token sai)	✓
F10 invoice	GET /orders/invoice?id=1 (admin)	200 HTML hoa don ORD-2026-0001	✓
F11 role	users co admin/manager/staff; quyen enforce server-side	✓	
F6 remember	Token hash trong remember_tokens, revoke khi logout	✓	
F12 cards	GET /public-leads/create	Hien thi 4 the tu van kem UI assets	✓
QW1 empty	DB khong co lead/doanh thu gan day (chart)	Hien empty-state thay vi cot 0 trong; sau re-seed ngay dong -> chart co du lieu	✓
QW2 source	GET /analytics	Khoi “Lead theo nguon” hien so lead theo website / facebook / zalo / referral / hotline	✓
QW3 KPI	GET /dashboard	3 KPI xu huong: ty le chuyen doi, ty le thanh toan, delta doanh thu MoM (mui ten + mau)	✓
QW4 submit	Submit form create/edit	Nut khoa + “Dang luu...” + spinner; F5/double-click khong tao trung	✓
QW5 i18n	Duyet cac trang sau re-seed	UI + du lieu tu DB hien tieng Viet co dau dung chinh ta (utf8mb4)	✓
C1 CRUD	Them/sua/xoa mem/khoi phuc khoa hoc	Ghi/sua DB + audit; xoa mem vao /courses/trash, khoi phuc lai list	✓

4.11 Problem Solving (tinh nang moi)

- **Vi sao F1 phai dung transaction?** Tao order va doi lead sang **converted** phai **toan ven**: neu order trung ma bi loi ma lead da bi danh dau converted thi du lieu sai lech. `rollback` dam bao “ca hai cung thanh cong hoac cung khong”.
- **Soft delete va unique index?** Soft delete giu du lieu phuc hoi duoc, nhung phai xu ly rang buoc unique: cot sinh `email_active` cho phep tai su dung email cua ban ghi da o thung rac ma khong vi pham `UNIQUE`.
- **Vi sao can audit log?** De **truy vet trach nhien** (ai doi/xoa gi) — thiet yeu cho he thong gan voi tien; chi admin xem, khong log mat khau/PII.
- **CSV injection?** O bat dau bang `= + - @` co the bi Excel hieu la cong thuc; em them dau nhay don de vo hieu hoa.

5 Ket luan

Qua Lab06 Final, em da xay dung hoan chinh **EduCRM — Training Center CRM**, mot Secure MVC Mini CRM chay duoc end-to-end voi database that,kiem thu that bang curl. Em nam vung:

- Kien truc **Front Controller + Router** voi 404/405 chuan HTTP.
- **Session/login an toan**: cookie flags, `session_regenerate_id(true)`, timeout, logout sach.
- **Form secure** + PRG + honeypot + rate limit.
- **PDO chuan** + prepared statement + whitelist sort -> chong SQL Injection.
- **MVC dung trach nhien**: Controller mong, Service rule, Repository SQL, View escape.
- **Unique constraint** + duplicate handling than thien, **EXPLAIN**/index, va **production safe error** + logging.

Phan lam them (Cau 3 — duoc cong diem):

- **CSRF token** cho moi form POST (create/update/delete/logout) qua `csrf_field()` + `verify_csrf()`.
- **Role permission**: chi admin duoc xoa lead/order; **staff** chi tao/sua (da test: staff POST delete khong xoa duoc).
- **Transaction** khi tao order (`beginTransaction/commit/rollBack`).
- **Dashboard thong ke**: tong lead, lead moi, tong phieu, doanh thu da thu, phan bo theo trang thai.
- **Filter theo status** ben canh search q.
- **Logging** vao `storage/logs/app.log` cho loi DB, login failed va honeypot.
- **Giao dien** polished, responsive (layout + partial dung chung) ma van giu dung kien truc MVC.

Phan da lam du / chua du (tu danh gia)

Theo yeu cau nop bai, em tu danh gia trung thuc muc do hoan thanh:

(A) Da lam DU — toan bo yeu cau bat buoc (Cau 1 + Cau 1A T01–T30 + Cau 1B TC01–TC25 + Cau 2):

- Front Controller / Router qua `public/index.php`, phan biet ro 404 vs 405 (T03, T27; TC22, TC23).
- Form cong khai secure: `trim` + validate server-side + old input + PRG + honeypot + rate limit theo session (T07–T09; TC07–TC09).
- Login / logout / session: cookie flags (HttpOnly, SameSite, Secure), `session_regenerate_id(true)`, timeout 1800s, logout sach (T04, T10–T12; TC01–TC06).
- Database **users** + 2 bang nghiep vu (**leads, orders**): PK, UNIQUE, FK, INDEX, `created_at/updated_at`; seed ≥ 20 dong/module (T13–T14).
- PDO chuan (`utf8mb4, ERRMODE_EXCEPTION, FETCH_ASSOC, EMULATE_PREPARES=false`) + prepared statement toan bo (T15–T16).
- CRUD Module A + Module B day du, POST cho `store/update/delete`; duplicate handling than thien khong lo `SQLSTATE` (T20–T23; TC10–TC16).
- Search / pagination / sort whitelist an toan, chong sort injection (T24–T25; TC17–TC20).

- EXPLAIN + nhan xet index (T29; TC25); MVC dung trach nhien (T17–T19); production safe error + logging (T28; TC24).
- /health JSON app/db (T26); GitHub + README + git log ≥ 6 commit (T30).
- 18 cau Problem Solving (Cau 2) tra loi gan truc tiep voi route/schema/code that cua project.

(B) Da lam THEM (Cau 3 — cong diem), vuot yeu cau: CSRF cho moi form POST; role permission enforce server-side (admin/manager/staff); soft delete + thung rac / khoi phuc (F2, M1); transaction khi convert lead (F1); audit log (F3); export CSV chong CSV-injection (F4); dashboard analytics + KPI xu huong (F5, QW3); JSON API + Bearer token (F7); hoa don in duoc (F10); **Module C — Quan ly Khoa hoc** (CRUD + anh whitelist + phan quyen); va nhom Quick Wins QW1–QW5 (empty-state, lead theo nguon, loading skeleton chong double-submit, UI tieng Viet co dau).

(C) Chua lam / gioi han — huong cai tien:

- Chua co test tu dong: moi kiem thu bang curl thu cong + checklist. Huong: **PHPUnit** (unit/integration) + **Postman collection** chay CI.
- Chua dong goi trien khai: chua co **Docker**/CI. Huong: **docker-compose** (php-fpm + MySQL) + GitHub Actions build/test.
- Anti-spam moi o muc co ban: rate limit theo **session** (de vuot bang cach xoa cookie). Huong: rate limit theo **IP** o tang web server + **reCAPTCHA** cho form cong khai.
- Anh minh hoa khoa hoc chon tu **whitelist** anh co san, chua ho tro **upload that** (can kiem duyet MIME/size/anh doc hai) — co y de an toan trong pham vi lab.
- Chua co lop **transaction** cho `order_items`/payment nhieu dong (hien order 1 dong); huong: tach bang `order_items` + wrap transaction khi tao nhieu dong.

Bang phu luc: requirements coverage

Yeu cau	Dat
Front Controller / Router / 404 / 405	✓
Form secure: validate server-side, old input, PRG	✓
Honeypot + rate limit cho form cong khai	✓
Login/logout/session regenerate/timeout/cookie flags	✓
Database users + 2 bang nghiep vu, PK/UNIQUE/INDEX/timestamp	✓
PDO chuan (utf8mb4, EXCEPTION, FETCH_ASSOC, EMU-LATE=false)	✓
Prepared statements cho moi input GET/POST	✓
CRUD Module A (leads) + Module B (orders), POST cho thao tac thay doi	✓
Search / pagination / sort whitelist an toan	✓
Duplicate handling khong lo SQLSTATE	✓
EXPLAIN + nhan xet index	✓
MVC: Controller mong, Service rule, Repository SQL, View escape	✓
404/405/500; production safe error + logging	✓
/health JSON app/db status	✓
README + route list + demo account + cau truc folder	✓
Lam them: CSRF, role permission, transaction, dashboard, logging	✓

GitHub: <https://github.com/lphhien112-gif/PHP->

Thu muc: PHP-Lab06/EduCRM/